

Tactical Playbook

Approved controlled catalogue

80 controlled tactic objects mapped to 40 capabilities and 40 paired anti-patterns across eight landing-zone design areas. The catalogue translates locked assessment findings into evidence-producing remediation paths for Azure, AWS and Google Cloud.

VERSION	1.0.0
STATUS	APPROVED - ACTIVE
SNAPSHOT	16 September 2026
SOURCE BASELINE	Landing Zone Assessment Global Source Register v1.0.0 - APPROVED baseline
CRITERIA BASELINE	80 criteria · 240 shared sub-criteria · Azure/AWS/GCP provider packs
AUTHORITY BOUNDARY	Implementation guidance only; activation follows locked findings and human authority

Core invariant

Assessment knowledge determines what the evidence means. The Tactical KB determines which approved remediation mechanism may be used. Customer evidence remains the only truth about the current estate.

Approved and active for controlled operational use. Subsequent KB enrichment is managed through normal versioning and change control.

Executive summary

Purpose

This playbook is the remediation layer of the Landing Zone Assessment Engine. It provides stable tactic identities, exact criterion mappings, activation rules, implementation activities, accountable ownership, expected evidence, acceptance criteria, verification and reassessment behavior.

It is intentionally not part of the assessment Knowledge Base. Capability and anti-pattern KB objects contain no tactic IDs. Mapping direction runs from the Tactical KB to assessment criteria, preserving independent versioning and preventing remediation content from influencing diagnosis.

A	Tenant, billing & organization construct	ORG	10
B	Identity & access	IDENTITY	10
C	Resource organization	RESOURCE	10
D	Network topology & connectivity	NETWORK	10
E	Security baseline	SECURITY	10
F	Management & observability	OPERATIONS	10
G	Governance & policy	GOVERNANCE	10
H	Platform automation & DevOps	AUTOMATION	10

Source and release status

The Global Source Register v1.0.0 is treated as the approved authoring baseline under the owner's governance decision. Source identity, authority tier, applicability and licensing constraints remain binding. Exact tactic-level locators and supported-claim boundaries will be refined as each capability and anti-pattern KB object is finalized.

Catalogue status

Version 1.0.0 is approved, active and usable. Every tactic has an approved identity, mapping, trigger, owner, implementation sequence, output set, acceptance boundary, verification method, risk control and reassessment rule. Future KB enrichment updates this controlled catalogue through normal versioning without suspending the current release.

Operating and authority model

Activation sequence

1	Evidence	Collect and validate current, attributable, in-scope customer evidence.
2	Diagnosis	Apply the Assessment KB and deterministic scoring; test anti-pattern absence explicitly.
3	Finding lock	Human-authorized finding state becomes eligible for exact tactic matching.
4	Tactic selection	Select only tactic IDs with approved explicit mappings; no title or similarity fallback.
5	Implementation	Execute controlled work and produce attributable implementation evidence.
6	Reassessment	Re-run the assessment against new evidence; tactics never close findings directly.

Permission boundaries

- Assessment KB owns definitions, evidence rules, scoring interpretation, false-positive guards and prohibited inferences.
- Tactical KB owns tactic identity, mapping, trigger, activities, outputs, acceptance, verification, risk controls and reassessment targets.
- Only verified customer evidence proves current state. Source publications and this playbook cannot prove that a customer implemented a control.
- Human authority retains evidence adjudication, finding lock, legal applicability, risk acceptance and production/lifecycle authorization.
- No finding means no mandatory tactic. No exact approved mapping means no tactic ID.

Change-control rule

A semantic change to a tactic's outcome, mechanism, ownership, required evidence, acceptance boundary, verification, mapping or do-not-use condition requires a new version, dependency update, referential-integrity validation and renewed approval. Editorial changes that do not alter meaning may remain within the current version under controlled review.

Canonical tactic content model

IDENTITY	Stable TAC-* ID, title, version, status and primary domain ownership.
MAPPING	Primary capability or anti-pattern, paired criterion, and explicit supporting/reuse mappings.
TRIGGER	Exact locked-finding state that makes the tactic eligible; absence of a locked finding prevents mandatory activation.
RATIONALE	Why the mechanism addresses the observed deficiency without becoming assessment evidence.
SOURCE GROUNDING	Approved source IDs, criterion mappings and applicability boundaries; locator enrichment follows normal controlled maintenance.
ACTIVITIES	Concrete implementation sequence, including containment, migration, control implementation and evidence capture.
OWNERSHIP	Responsible owner plus supporting roles; human authority remains explicit.
OUTPUTS	Evidence-producing deliverables that can be verified independently.
ACCEPTANCE	Observable conditions required before implementation may be called complete.
VERIFICATION	Provider-pack queries, configuration exports and tests used to check implementation and effectiveness.
RISK CONTROL	Primary implementation hazard, sequencing, rollback and do-not-use conditions.
REASSESSMENT	Criteria and anti-patterns that must be reassessed using new evidence.
CLOSURE	Completion creates evidence only; it never changes findings, scores, gates, compliance, risk acceptance or authorization.

Provider realization

Azure, AWS and GCP rows are evidence and implementation contracts beneath the shared intent. A tactic keeps one stable identity when objective, mechanism, outputs, acceptance and verification are materially equivalent. Provider-specific product objects appear in implementation and verification; they do not create separate tactics merely because product names differ.

Reuse rule

Reuse an existing tactic ID only when objective, mechanism, artifacts, acceptance boundary, verification and reassessment are materially equivalent. Create a new ID when the required control outcome, mechanism, owner, evidence or acceptance boundary is materially distinct. Supporting mappings in this release are approved; any future mapping change follows versioned change control and referential-integrity validation.

Contents

1	Executive summary	Purpose, scope, status and source basis
2	Operating and authority model	Evidence-gated activation and permission boundaries
3	Canonical tactic content model	Required fields, provider realization and reuse rule
4	Catalogue index	All 80 tactic IDs and criterion mappings
5	Domain A - Tenant, billing & organization construct	Namespace ORG; five capability and five corrective tactics
6	Domain B - Identity & access	Namespace IDENTITY; five capability and five corrective tactics
7	Domain C - Resource organization	Namespace RESOURCE; five capability and five corrective tactics
8	Domain D - Network topology & connectivity	Namespace NETWORK; five capability and five corrective tactics
9	Domain E - Security baseline	Namespace SECURITY; five capability and five corrective tactics
10	Domain F - Management & observability	Namespace OPERATIONS; five capability and five corrective tactics
11	Domain G - Governance & policy	Namespace GOVERNANCE; five capability and five corrective tactics
12	Domain H - Platform automation & DevOps	Namespace AUTOMATION; five capability and five corrective tactics
13	Approved source identity appendix	43 registered publisher identities
14	Approved release and controlled refinement	Active status, maintenance path and release controls

Use the PDF outline/bookmarks to navigate directly to each domain and appendix.

Catalogue index

Every criterion has an approved remediation path. Primary activation follows the exact mapping shown; paired and supporting mappings do not permit inference or similarity matching.

TAC-ORG-A1-01	Establish the Authoritative Organization Root and Inventory Boundary	A1	AP-A1, A3, A4, F2
TAC-ORG-A2-01	Separate and Protect the Management Plane	A2	AP-A2, B4, C2, E5
TAC-ORG-A3-01	Align Billing, Contract and Technical Ownership	A3	AP-A3, A1, A4, G4
TAC-ORG-A4-01	Define and Lock Administrative Boundaries	A4	AP-A4, A1, B4, G3
TAC-ORG-A5-01	Implement Tested Root Recovery and Emergency Access	A5	AP-A5, B5, F4, F3
TAC-ORG-AP-A1-01	Contain Shadow Tenants and Reconcile the Production Estate	AP-A1	A1, A3, A4, F2
TAC-ORG-AP-A2-01	Remove Workloads and Daily Users from the Management Plane	AP-A2	A2, B4, C2, E5
TAC-ORG-AP-A3-01	Reconcile Orphaned Billing and Technical Estates	AP-A3	A3, A1, A4, G4
TAC-ORG-AP-A4-01	Bound External Root Access and Undeclared Estates	AP-A4	A4, A1, B4, G3
TAC-ORG-AP-A5-01	Recover Control of Unowned Root Credentials	AP-A5	A5, B5, F4, F3
TAC-IDENTITY-B1-01	Federate Workforce Access Through the Corporate Identity Provider	B1	AP-B1, B2, B5, A5
TAC-IDENTITY-B2-01	Implement Time-Bound Privileged Access	B2	AP-B2, B1, B4, B5
TAC-IDENTITY-B3-01	Replace Long-Lived Credentials with Workload Identity	B3	AP-B3, E4, H2, H5
TAC-IDENTITY-B4-01	Enforce Least Privilege Through the Resource Hierarchy	B4	AP-B4, A4, B2, G1
TAC-IDENTITY-B5-01	Establish Monitored Break-Glass Access	B5	AP-B5, A5, F3, E2
TAC-IDENTITY-AP-B1-01	Remove Standing Root-Equivalent Access	AP-B1	B1, B2, B4, B5, A5
TAC-IDENTITY-AP-B2-01	Retire Cloud-Local Human Identity as the Primary Access Path	AP-B2	B2, B1, B5, A5
TAC-IDENTITY-AP-B3-01	Discover, Revoke and Replace Long-Lived Keys	AP-B3	B3, E4, H2, H5
TAC-IDENTITY-AP-B4-01	Remove Unscoped Root-Level Owner Access	AP-B4	B4, A4, B2, G1
TAC-IDENTITY-AP-B5-01	Create or Repair Missing and Unmonitored Break-Glass	AP-B5	B5, A5, F3, E2
TAC-RESOURCE-C1-01	Design a Policy-Bearing Resource Hierarchy	C1	AP-C1, G1, A1, C5
TAC-RESOURCE-C2-01	Separate Platform and Application Landing Zones	C2	AP-C2, A2, D1, E5
TAC-RESOURCE-C3-01	Enforce Naming and Tagging at Creation Time	C3	AP-C3, G4, H2, F2
TAC-RESOURCE-C4-01	Implement Governed Isolation-Unit Vending	C4	AP-C4, H2, H4, C3
TAC-RESOURCE-C5-01	Separate Production and Non-Production Boundaries	C5	AP-C5, D5, B4, G1
TAC-RESOURCE-AP-C1-01	Restructure Flat Subscription, Account or Project Sprawl	AP-C1	C1, G1, A1, C5
TAC-RESOURCE-AP-C2-01	Extract Applications from Platform Landing Zones	AP-C2	C2, A2, D1, E5
TAC-RESOURCE-AP-C3-01	Replace Ad-Hoc Naming and Tag Theatre with Enforced Metadata	AP-C3	C3, G4, H2, F2
TAC-RESOURCE-AP-C4-01	Replace ClickOps Birth with a Governed Vending Path	AP-C4	C4, H2, H4, C3
TAC-RESOURCE-AP-C5-01	Split Mixed Environments and Close Cross-Environment Paths	AP-C5	C5, D5, B4, G1
TAC-NETWORK-D1-01	Establish a Governed Hub and Inspection Topology	D1	AP-D1, D2, D5, E2
TAC-NETWORK-D2-01	Centralize Ownership of Hybrid Connectivity	D2	AP-D2, D1, D3, F3
TAC-NETWORK-D3-01	Provide Central Private DNS Resolution	D3	AP-D3, D2, D4, F4
TAC-NETWORK-D4-01	Enforce Private-by-Default Service Access	D4	AP-D4, G2, D3, E1
TAC-NETWORK-D5-01	Enforce Landing-Zone Network Segmentation	D5	AP-D5, C5, D1, B4
TAC-NETWORK-AP-D1-01	Consolidate Per-Application Internet Edges	AP-D1	D1, D2, D5, E2
TAC-NETWORK-AP-D2-01	Segment the Flat Global Network	AP-D2	D2, D5, D1, B4, G2
TAC-NETWORK-AP-D3-01	Eliminate Split-Brain and Unowned Private DNS	AP-D3	D3, D2, D4, F4
TAC-NETWORK-AP-D4-01	Close Public-by-Default Endpoints	AP-D4	D4, G2, D3, E1
TAC-NETWORK-AP-D5-01	Dismantle the Unmanaged Peering Mesh	AP-D5	D5, C5, D1, B4
TAC-SECURITY-E1-01	Deploy a Preventive Landing-Zone Security Baseline	E1	AP-E1, G1, G2, H1
TAC-SECURITY-E2-01	Centralize Organization-Level Threat Detection	E2	AP-E2, F1, F3, E5

TAC-SECURITY-E3-01	Operationalize Encryption and Key Management	E3	AP-E3, E4, F4, B3
TAC-SECURITY-E4-01	Implement Managed Secrets and Rotation	E4	AP-E4, B3, H2, E3
TAC-SECURITY-E5-01	Establish the Security Operations Landing Zone and RACI	E5	AP-E5, E2, F1, F3
TAC-SECURITY-AP-E1-01	Convert Optional Security into Mandatory Guardrails	AP-E1	E1, G1, G2, H1
TAC-SECURITY-AP-E2-01	Consolidate SIEM and Detection Islands	AP-E2	E2, F1, F3, E5
TAC-SECURITY-AP-E3-01	Remove Keys from Code and Prove Real Key Use	AP-E3	E3, E4, F4, B3
TAC-SECURITY-AP-E4-01	Remove Secrets from Pipelines, Wikis and Spreadsheets	AP-E4	E4, B3, H2, E3
TAC-SECURITY-AP-E5-01	Replace After-the-Fact Security Tickets with Embedded Ownership	AP-E5	E5, E2, F1, F3
TAC-OPERATIONS-F1-01	Centralize and Protect Activity and Audit Logs	F1	AP-F1, E2, F3, G5
TAC-OPERATIONS-F2-01	Make Live Control-Plane Inventory the System of Record	F2	AP-F2, A1, C1, G5
TAC-OPERATIONS-F3-01	Monitor the Landing-Zone Platform Baseline	F3	AP-F3, D2, E2, F1
TAC-OPERATIONS-F4-01	Implement and Exercise Landing-Zone Backup and Restore	F4	AP-F4, A5, D3, H1
TAC-OPERATIONS-F5-01	Standardize the Platform Update and Agent Baseline	F5	AP-F5, E1, H1, H5
TAC-OPERATIONS-AP-F1-01	Recover Logs from Producing Accounts and Correct Retention	AP-F1	F1, E2, F3, G5
TAC-OPERATIONS-AP-F2-01	Replace Stale Diagrams with Current API Inventory	AP-F2	F2, A1, C1, G5
TAC-OPERATIONS-AP-F3-01	Extend Monitoring Beyond Applications	AP-F3	F3, D2, E2, F1
TAC-OPERATIONS-AP-F4-01	Recover Unprotected Platform State	AP-F4	F4, A5, D3, H1
TAC-OPERATIONS-AP-F5-01	Retire Snowflake Images and Unmanaged Agents	AP-F5	F5, E1, H1, H5
TAC-GOVERNANCE-G1-01	Assign and Inherit Guardrails from the Root	G1	AP-G1, C1, E1, H1
TAC-GOVERNANCE-G2-01	Deny High-Blast-Radius Insecure Defaults	G2	AP-G2, D4, E1, G3
TAC-GOVERNANCE-G3-01	Govern Exceptions with Owner, Expiry and Review	G3	AP-G3, G1, G2, H5
TAC-GOVERNANCE-G4-01	Enforce Cost, Tag and Region Guardrails	G4	AP-G4, A3, C3, H2
TAC-GOVERNANCE-G5-01	Produce Queryable Compliance Evidence	G5	AP-G5, F2, F1, E1
TAC-GOVERNANCE-AP-G1-01	Convert Policy Documents into Enforced Control-Plane Assignments	AP-G1	G1, C1, E1, H1
TAC-GOVERNANCE-AP-G2-01	Replace Root Allow-All with a Minimal Preventive Baseline	AP-G2	G2, D4, E1, G3
TAC-GOVERNANCE-AP-G3-01	Expire or Reauthorize Permanent Exemptions	AP-G3	G3, G1, G2, H5
TAC-GOVERNANCE-AP-G4-01	Establish Minimum Commercial and Geographic Controls	AP-G4	G4, A3, C3, H2
TAC-GOVERNANCE-AP-G5-01	Replace Screenshot Compliance with Reproducible Exports	AP-G5	G5, F2, F1, E1
TAC-AUTOMATION-H1-01	Codify and Version the Landing-Zone Platform	H1	AP-H1, H3, H5, F4
TAC-AUTOMATION-H2-01	Implement an End-to-End Landing-Zone Vending Pipeline	H2	AP-H2, C4, H4, C3
TAC-AUTOMATION-H3-01	Detect, Triage and Correct Platform Drift	H3	AP-H3, H1, H5, G5
TAC-AUTOMATION-H4-01	Provide Guardrailed Platform Self-Service	H4	AP-H4, H2, C4, G4
TAC-AUTOMATION-H5-01	Govern Platform Change and Emergency Hotfixes	H5	AP-H5, H1, H3, F4
TAC-AUTOMATION-AP-H1-01	Bring the ClickOps Platform Under Code Control	AP-H1	H1, H3, H5, F4
TAC-AUTOMATION-AP-H2-01	Replace Email Vending with a Controlled Product Workflow	AP-H2	H2, C4, H4, C3
TAC-AUTOMATION-AP-H3-01	Reconcile Accepted Drift and Restore Code Authority	AP-H3	H3, H1, H5, G5
TAC-AUTOMATION-AP-H4-01	Remove Ticket-Only Platform Bottlenecks	AP-H4	H4, H2, C4, G4
TAC-AUTOMATION-AP-H5-01	Reconcile Undocumented Hotfixes into the Controlled Baseline	AP-H5	H5, H1, H3, F4

Domain A - Tenant, billing & organization construct

Namespace: ORG · 10 tactic objects · Primary ownership: Cloud Platform Owner

Workshop themes

- Where is the authoritative cloud organization, and who owns it?
- Are production workloads forbidden from the management/payer plane?
- Does billing, contract and technical ownership describe the same estate?

Domain control intent

Use the ORG catalogue only after an exact Domain A finding is locked. Capability-building tactics establish the target mechanism; anti-pattern tactics contain and correct the harmful observed state. Supporting roles: Identity, Finance/FinOps, Security and Enterprise Architecture.

TAC-ORG-A1-01

CAPABILITY · DOMAIN A

Establish the Authoritative Organization Root and Inventory Boundary

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: A1 · Pair: AP-A1 · Supporting/reuse: A3, A4, F2
PRIMARY OWNER	Cloud Platform Owner
SUPPORTING ROLES	Identity, Finance/FinOps, Security and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-CAF-LZ, SRC-MS-CAF-DESIGN-AREAS, SRC-AWS-ORG-STRATEGY, SRC-AWS-CT, SRC-GCP-LZ, SRC-GCP-HIERARCHY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that A1 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-A1 finding requires the capability as the replacement control.

Control purpose and rationale

A single declared tenant, organization or management account is the landing-zone root. Production resources do not live in unmanaged side-tenants. The root is inventoryable. This tactic provides the controlled remediation mechanism for the locked A1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for A1 using live control-plane inventory.
- Design the mechanism: Establish the Authoritative Organization Root and Inventory Boundary; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- approved root and scope record
- current hierarchy export
- owner and billing mapping
- stray-estate disposition register
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a single declared tenant, organization or management account that is the landing-zone root?
- Evidence answers YES: Can that root be exported as a hierarchy (management groups, OUs or folders) with a named owner?
- Evidence answers YES: Are production workloads forbidden from existing outside that root?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Entra tenant ID, Tenant Root Group, MCA/EA billing account attached to the tenant.
- AWS: Organizations management account, Root, ALL_FEATURES enabled; no extra orgs holding prod accounts.
- GCP: Organization resource + Cloud Identity; billing account linked to the org, not to a lone project.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Migration or consolidation may interrupt production or create an ungoverned interim estate.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess A1, AP-A1, A3, A4, F2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-ORG-A2-01

CAPABILITY · DOMAIN A

Separate and Protect the Management Plane

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: A2 · Pair: AP-A2 · Supporting/reuse: B4, C2, E5
PRIMARY OWNER	Cloud Platform Owner
SUPPORTING ROLES	Identity, Finance/FinOps, Security and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-CAF-LZ, SRC-AWS-ORG-STRATEGY, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that A2 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-A2 finding requires the capability as the replacement control.

Control purpose and rationale

The management, payer or bootstrap plane runs only organization services. Application workloads, data and developer sandboxes are not hosted there. This tactic provides the controlled remediation mechanism for the locked A2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for A2 using live control-plane inventory.
- Design the mechanism: Separate and Protect the Management Plane; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- management-plane service boundary
- workload inventory and migration plan
- separate privileged-access model
- post-migration control-plane export
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is the management, payer or bootstrap account free of application workloads?
- Evidence answers YES: Are only organization-level services (identity, logging, policy, connectivity) deployed there?
- Evidence answers YES: Is access to that plane separately controlled and reviewed?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No app resource groups in Management / Identity / Connectivity platform subscriptions beyond platform services.
- AWS: Organizations management account has no application VPCs, data stores or IAM users for app teams.
- GCP: No application folders or projects under the bootstrap/seed project; org-level services only.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Moving workloads before dependencies are mapped can damage organization-level services.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess A2, AP-A2, B4, C2, E5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-ORG-A3-01

CAPABILITY · DOMAIN A

Align Billing, Contract and Technical Ownership

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: A3 · Pair: AP-A3 · Supporting/reuse: A1, A4, G4
PRIMARY OWNER	Cloud Commercial / FinOps Owner
SUPPORTING ROLES	Cloud Platform, Finance, Procurement and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-CAF-DESIGN-AREAS, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that A3 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-A3 finding requires the capability as the replacement control.

Control purpose and rationale

Commercial construct (EA/MCA, payer, billing account) matches the technical organization. Cost, invoice and account ownership can be named. This tactic provides the controlled remediation mechanism for the locked A3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for A3 using live control-plane inventory.
- Design the mechanism: Align Billing, Contract and Technical Ownership; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- billing-to-hierarchy reconciliation
- contract and payer ownership register
- orphaned-scope disposition decisions
- cost allocation validation
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is the billing account, payer or enrollment mapped to the same organization as the technical hierarchy?
- Evidence answers YES: Can every in-scope subscription, account or project be attributed to a billing owner?
- Evidence answers YES: Are orphaned billing scopes (unused enrollments, extra payers) identified and closed or explicitly out of scope?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: MCA/EA billing account, billing profiles, invoice sections vs management group tree.
- AWS: Consolidated billing, payer account, linked accounts; AWS Organizations vs Billing Conductor if used.
- GCP: Cloud Billing account, org-level billing export, projects billed outside the org.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Commercial changes may alter discounts, commitments, invoices or tax treatment.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess A3, AP-A3, A1, A4, G4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-ORG-A4-01

CAPABILITY · DOMAIN A

Define and Lock Administrative Boundaries

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: A4 · Pair: AP-A4 · Supporting/reuse: A1, B4, G3
PRIMARY OWNER	Cloud Platform Owner
SUPPORTING ROLES	Identity, Finance/FinOps, Security and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-CAF-LZ, SRC-AWS-CT, SRC-GCP-LZ, SRC-NIST-800-53
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that A4 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-A4 finding requires the capability as the replacement control.

Control purpose and rationale

Partner, guest, sandbox and merged-company tenants are named. The assessment scope is a declared set of roots, not 'whatever we found'. This tactic provides the controlled remediation mechanism for the locked A4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for A4 using live control-plane inventory.
- Design the mechanism: Define and Lock Administrative Boundaries; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- in-scope/out-of-scope root register
- external administrator inventory
- Step 0 boundary approval
- time-bound access and exclusion records
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are partner, guest, sandbox and acquisition tenants explicitly in-scope or out-of-scope?
- Evidence answers YES: Is there an inventory of extra directories, organizations or billing accounts?
- Evidence answers YES: Does Step 0 lock the in-scope roots before scoring begins?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Extra Entra tenants, B2B guest tenants, Azure DevOps orgs, unused EA enrollments.
- AWS: Standalone accounts outside the org, extra Organizations, AWS Gov/China partitions if present.
- GCP: Projects with no parent org, extra Google Workspace domains, unmanaged GCP folders.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A boundary decision can hide material risk if exclusions are used to avoid assessment.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess A4, AP-A4, A1, B4, G3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-ORG-A5-01

CAPABILITY · DOMAIN A

Implement Tested Root Recovery and Emergency Access

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: A5 · Pair: AP-A5 · Supporting/reuse: B5, F4, F3
PRIMARY OWNER	Cloud Platform Owner
SUPPORTING ROLES	Identity, Finance/FinOps, Security and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-CAF-IDENTITY, SRC-MS-ENTRA-PIM, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS, SRC-CIS-AZURE, SRC-CIS-AWS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that A5 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-A5 finding requires the capability as the replacement control.

Control purpose and rationale

Loss of the cloud-root identity does not mean loss of the estate. Emergency access is designed, stored, tested and monitored — not a password in a ticket. This tactic provides the controlled remediation mechanism for the locked A5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for A5 using live control-plane inventory.
- Design the mechanism: Implement Tested Root Recovery and Emergency Access; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- root recovery runbook
- dual-control custody record
- emergency-access test evidence
- root-use alert evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a documented emergency-access path to the tenant, management account or org super-admin?
- Evidence answers YES: Is that path stored offline or in a vault, with dual control, and tested on a cadence?
- Evidence answers YES: Are root/emergency authentications logged and alerted?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Break-glass Entra cloud-only accounts, PIM for Global Admin, emergency access package.
- AWS: Root MFA, hardware key, no root access keys; Organizations delegated admin; Account Recovery.
- GCP: Super-admin dual control, recovery email/phone, organization-admin not bound to one human.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Changing root credentials or recovery contacts can lock administrators out of the estate.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess A5, AP-A5, B5, F4, F3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-ORG-AP-A1-01

ANTI-PATTERN · DOMAIN A

Contain Shadow Tenants and Reconcile the Production Estate

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-A1 · Pair: A1 · Supporting/reuse: A3, A4, F2
PRIMARY OWNER	Cloud Platform Owner
SUPPORTING ROLES	Identity, Finance/FinOps, Security and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-CAF-LZ, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY, SRC-GCP-LZ
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-A1 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Production lives in extra directories, organizations or personal accounts that the platform team cannot inventory or govern. This tactic provides the controlled remediation mechanism for the locked AP-A1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of shadow tenants and unmanaged orgs and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Establish the Authoritative Organization Root and Inventory Boundary.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-A1 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- approved root and scope record
- current hierarchy export
- owner and billing mapping
- stray-estate disposition register
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Do production workloads exist in tenants, organizations or accounts outside the declared root?
- Absence test answers NO across the in-scope estate: Is there no maintained inventory of extra directories or billing relationships?
- Absence test answers NO across the in-scope estate: Are mergers, partners or 'temporary' clouds still running production without a landing-zone owner?
- The paired capability A1 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Second Entra tenant with subscriptions; MSDN / personal tenants used for prod.
- AWS: Member accounts not in the org; root-less standalone prod accounts.
- GCP: No-organization projects; billing on a user account.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Migration or consolidation may interrupt production or create an ungoverned interim estate.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-A1, A1, A3, A4, F2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-ORG-AP-A2-01

ANTI-PATTERN · DOMAIN A

Remove Workloads and Daily Users from the Management Plane

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-A2 · Pair: A2 · Supporting/reuse: B4, C2, E5
PRIMARY OWNER	Cloud Platform Owner
SUPPORTING ROLES	Identity, Finance/FinOps, Security and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-CAF-LZ, SRC-AWS-ORG-STRATEGY, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-A2 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Applications, data lakes or developer sandboxes sit in the management, payer or tenant-root subscription. A landing-zone change now risks the company. This tactic provides the controlled remediation mechanism for the locked AP-A2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of workloads in the management plane and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Separate and Protect the Management Plane.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-A2 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- management-plane service boundary
- workload inventory and migration plan
- separate privileged-access model
- post-migration control-plane export
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are application resources deployed in the management, payer or bootstrap account?
- Absence test answers NO across the in-scope estate: Would a landing-zone rebuild require migrating production out of that plane first?
- Absence test answers NO across the in-scope estate: Do app teams have standing contributor rights on the management plane?
- The paired capability A2 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: App resource groups in the Management or Tenant Root subscription.
- AWS: Application VPCs, S3 data or RDS in the Organizations management account.
- GCP: App GKE or data projects under the seed/bootstrap project.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Moving workloads before dependencies are mapped can damage organization-level services.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-A2, A2, B4, C2, E5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-ORG-AP-A3-01

ANTI-PATTERN · DOMAIN A

Reconcile Orphaned Billing and Technical Estates

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-A3 · Pair: A3 · Supporting/reuse: A1, A4, G4
PRIMARY OWNER	Cloud Commercial / FinOps Owner
SUPPORTING ROLES	Cloud Platform, Finance, Procurement and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-CAF-DESIGN-AREAS, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-A3 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Finance pays a bill that platform cannot map. Technical owners cannot name the contract. Scope debates replace assessment. This tactic provides the controlled remediation mechanism for the locked AP-A3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of billing split from technical ownership and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Align Billing, Contract and Technical Ownership.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-A3 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- billing-to-hierarchy reconciliation
- contract and payer ownership register
- orphaned-scope disposition decisions
- cost allocation validation
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Can platform and finance not agree which subscriptions, accounts or projects are in-scope?
- Absence test answers NO across the in-scope estate: Are invoices received for clouds that have no landing-zone owner?
- Absence test answers NO across the in-scope estate: Is cost allocation blocked because billing structure does not match the hierarchy?
- The paired capability A3 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: EA enrollment not matching management groups; Azure Plan vs tenant mismatch.
- AWS: Payer account in a different org; linked accounts billed but not in Organizations.
- GCP: Billing account owned by a user; projects billed outside the org.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Commercial changes may alter discounts, commitments, invoices or tax treatment.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-A3, A3, A1, A4, G4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-ORG-AP-A4-01

ANTI-PATTERN · DOMAIN A

Bound External Root Access and Undeclared Estates

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-A4 · Pair: A4 · Supporting/reuse: A1, B4, G3
PRIMARY OWNER	Cloud Platform Owner
SUPPORTING ROLES	Identity, Finance/FinOps, Security and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-CAF-LZ, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-A4 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

External identities hold owner-equivalent rights at tenant, organization or management-account level with no expiry. This tactic provides the controlled remediation mechanism for the locked AP-A4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of unbounded guest or partner access at root and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Define and Lock Administrative Boundaries.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-A4 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- in-scope/out-of-scope root register
- external administrator inventory
- Step 0 boundary approval
- time-bound access and exclusion records
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Do guest, partner or vendor identities hold owner-equivalent roles at the root?
- Absence test answers NO across the in-scope estate: Is that access standing (no expiry, no dual control)?
- Absence test answers NO across the in-scope estate: Is there no review of external admin at the organization plane?
- The paired capability A4 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Guest Global Admin or Owner at Tenant Root Group.
- AWS: External IAM or assumed roles with AdministratorAccess on the management account.
- GCP: External users with roles/resourcemanager.organizationAdmin.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A boundary decision can hide material risk if exclusions are used to avoid assessment.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-A4, A4, A1, B4, G3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-ORG-AP-A5-01

ANTI-PATTERN · DOMAIN A

Recover Control of Unowned Root Credentials

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-A5 · Pair: A5 · Supporting/reuse: B5, F4, F3
PRIMARY OWNER	Cloud Platform Owner
SUPPORTING ROLES	Identity, Finance/FinOps, Security and Enterprise Architecture
APPROVED SOURCE IDS	SRC-MS-ENTRA-PIM, SRC-AWS-SRA, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-A5 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Root, super-admin or Global Admin credentials are shared, unlogged, or known only to a departed person. This tactic provides the controlled remediation mechanism for the locked AP-A5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of unowned root credentials and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Implement Tested Root Recovery and Emergency Access.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-A5 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- root recovery runbook
- dual-control custody record
- emergency-access test evidence
- root-use alert evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are root or super-admin credentials shared, stored in email, or unused-and-unknown?
- Absence test answers NO across the in-scope estate: Is there no MFA or hardware key on the cloud root?
- Absence test answers NO across the in-scope estate: Would the estate be unrecoverable if one person left?
- The paired capability A5 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Shared Global Admin password; no break-glass; no PIM.
- AWS: Root access keys exist; root MFA unset; root used as a daily login.
- GCP: Single super-admin; recovery options stale; no 2-step verification.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Changing root credentials or recovery contacts can lock administrators out of the estate.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-A5, A5, B5, F4, F3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

Domain B - Identity & access

Namespace: IDENTITY · 10 tactic objects · Primary ownership: Identity and Access Owner

Workshop themes

- How does a human get access, and how is it taken away?
- How is privileged access made eligible, time-bound and logged?
- How do workloads authenticate without long-lived secrets?

Domain control intent

Use the IDENTITY catalogue only after an exact Domain B finding is locked. Capability-building tactics establish the target mechanism; anti-pattern tactics contain and correct the harmful observed state. Supporting roles: Cloud Platform, Security Operations and Application Owners.

TAC-IDENTITY-B1-01

CAPABILITY · DOMAIN B

Federate Workforce Access Through the Corporate Identity Provider

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: B1 · Pair: AP-B1 · Supporting/reuse: B2, B5, A5
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-MS-CAF-IDENTITY, SRC-AWS-IDENTITY-CENTER, SRC-GCP-LZ, SRC-NIST-800-207, SRC-NCSC-CLOUD-PRINCIPLES
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that B1 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-B1 finding requires the capability as the replacement control.

Control purpose and rationale

Workforce access uses the corporate identity provider. Cloud-local users are not the primary human identity. Joiners, movers and leavers follow the IdP. This tactic provides the controlled remediation mechanism for the locked B1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for B1 using live control-plane inventory.
- Design the mechanism: Federate Workforce Access Through the Corporate Identity Provider; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- federation design and configuration
- joiner/mover/leaver integration
- local-user exception register
- authentication and deprovisioning tests
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is workforce sign-in federated from the corporate identity provider to every in-scope cloud?
- Evidence answers YES: Are cloud-local human users the exception, inventoried, and expiry-bound?
- Evidence answers YES: Does leaver processing in the IdP actually remove cloud access?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Entra ID / AD FS federation; cloud-only users listed and justified.
- AWS: IAM Identity Center (SSO) to the IdP; IAM users for humans are exceptions.
- GCP: Cloud Identity / Workforce Identity Federation; no standing Google user as org admin for staff.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A federation cutover without tested emergency access can cause a broad administrative outage.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess B1, AP-B1, B2, B5, A5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-IDENTITY-B2-01

CAPABILITY · DOMAIN B

Implement Time-Bound Privileged Access

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: B2 · Pair: AP-B2 · Supporting/reuse: B1, B4, B5
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-MS-ENTRA-PIM, SRC-MS-CAF-IDENTITY, SRC-AWS-IDENTITY-CENTER, SRC-GCP-FOUNDATIONS, SRC-NIST-800-53
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that B2 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-B2 finding requires the capability as the replacement control.

Control purpose and rationale

Privileged roles are eligible, activated, time-bound and logged. Standing Global Admin, AdministratorAccess or organizationAdmin for humans is not the operating model. This tactic provides the controlled remediation mechanism for the locked B2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for B2 using live control-plane inventory.
- Design the mechanism: Implement Time-Bound Privileged Access; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- privileged-role eligibility model
- activation and approval rules
- standing-access removal record
- activation logs and review evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are privileged roles eligible rather than permanently assigned to humans?
- Evidence answers YES: Is activation time-bound, approved or justified, and written to an audit log?
- Evidence answers YES: Is standing owner-equivalent access on humans treated as an exception with an expiry?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Entra PIM eligible roles, activation logs, Access Reviews.
- AWS: Identity Center permission sets, session duration, CloudTrail; no standing AdministratorAccess on humans.
- GCP: PAM / IAM Conditions / time-bound grants; no standing roles/owner on users at org root.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Removing standing privilege before operational roles are validated may block incident response.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess B2, AP-B2, B1, B4, B5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-IDENTITY-B3-01

CAPABILITY · DOMAIN B

Replace Long-Lived Credentials with Workload Identity

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: B3 · Pair: AP-B3 · Supporting/reuse: E4, H2, H5
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-MS-CAF-IDENTITY, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS, SRC-NCSC-CLOUD-PRINCIPLES
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that B3 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-B3 finding requires the capability as the replacement control.

Control purpose and rationale

Compute, pipelines and services authenticate with federated or managed identities. Long-lived access keys and downloaded JSON keys are not the default. This tactic provides the controlled remediation mechanism for the locked B3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for B3 using live control-plane inventory.
- Design the mechanism: Replace Long-Lived Credentials with Workload Identity; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- machine identity inventory
- federation/managed-identity configuration
- key and secret revocation log
- credential-lifetime test results
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Do platform and application workloads use managed or federated identities rather than stored keys?
- Evidence answers YES: Are remaining long-lived keys inventoried, aged, and on a removal path?
- Evidence answers YES: Do CI/CD platforms federate into the cloud rather than store cloud secrets?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Managed identities, workload identity federation (GitHub/ADO), no client secrets in pipelines.
- AWS: IRSA / instance profiles / IAM Roles Anywhere; IAM User access keys for workloads absent or aged.
- GCP: Attached service accounts, Workload Identity Federation; no downloaded JSON keys for automation.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Premature key revocation can stop pipelines and production integrations.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess B3, AP-B3, E4, H2, H5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-IDENTITY-B4-01

CAPABILITY · DOMAIN B

Enforce Least Privilege Through the Resource Hierarchy

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: B4 · Pair: AP-B4 · Supporting/reuse: A4, B2, G1
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-MS-CAF-IDENTITY, SRC-AWS-SCP, SRC-GCP-ORGPOLICY, SRC-NIST-800-53
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that B4 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-B4 finding requires the capability as the replacement control.

Control purpose and rationale

Role assignment follows the hierarchy. Owner-equivalent at tenant, org or management-group root is rare, named, and not used for daily work. This tactic provides the controlled remediation mechanism for the locked B4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for B4 using live control-plane inventory.
- Design the mechanism: Enforce Least Privilege Through the Resource Hierarchy; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- role model and inheritance design
- root-level assignment inventory
- rightsizing decisions
- effective-access verification export
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are role assignments scoped to the landing zone or workload, not the organization root, by default?
- Evidence answers YES: Is Owner / AdministratorAccess / roles/owner at root limited to a break-glass set?
- Evidence answers YES: Can the platform show who has owner-equivalent rights, where, and why?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: MG/subscription/RG RBAC; Owner at Tenant Root Group listed; custom roles over Owner.
- AWS: SCPs + Identity Center permission sets by OU; IAM policies not attached at org root for humans.
- GCP: Folder/project IAM; organization-level roles/owner and editor listed and justified.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Role reduction based only on assigned permissions can miss real operational dependencies.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess B4, AP-B4, A4, B2, G1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-IDENTITY-B5-01

CAPABILITY · DOMAIN B

Establish Monitored Break-Glass Access

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: B5 · Pair: AP-B5 · Supporting/reuse: A5, F3, E2
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-MS-ENTRA-PIM, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS, SRC-NIST-800-53
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that B5 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-B5 finding requires the capability as the replacement control.

Control purpose and rationale

Emergency access exists, is dual-controlled, is unused in daily operations, and fires a detection when used. This tactic provides the controlled remediation mechanism for the locked B5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for B5 using live control-plane inventory.
- Design the mechanism: Establish Monitored Break-Glass Access; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- emergency identity set
- dual-control operating procedure
- alert and escalation configuration
- scheduled activation-test record
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Do named break-glass identities exist, with dual control, outside normal federation failure modes?
- Evidence answers YES: Are they excluded from daily use by policy and culture?
- Evidence answers YES: Does use generate a high-severity alert within minutes?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Cloud-only break-glass accounts, excluded from PIM but alerted via Entra / Sentinel.
- AWS: Break-glass IAM role or root procedure; CloudTrail + GuardDuty / EventBridge alert on use.
- GCP: Break-glass super-admin or PAM emergency grant; Cloud Audit Logs alert.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Break-glass credentials can become a permanent bypass if normal use is not prevented and monitored.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess B5, AP-B5, A5, F3, E2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-IDENTITY-AP-B1-01

ANTI-PATTERN · DOMAIN B

Remove Standing Root-Equivalent Access

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-B1 · Pair: B1 · Supporting/reuse: B2, B4, B5, A5
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-MS-ENTRA-PIM, SRC-MS-CAF-IDENTITY, SRC-AWS-IDENTITY-CENTER, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-B1 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Humans hold permanent Global Admin, AdministratorAccess or organizationAdmin. Privilege is a lifestyle, not an event. This tactic provides the controlled remediation mechanism for the locked AP-B1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of standing root-equivalent access and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: time-bound, least-privilege administration with monitored emergency access.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-B1 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- root-equivalent role inventory
- privilege reduction and eligibility design
- standing-access removal record
- effective-access and activation review
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Do humans hold standing owner-equivalent roles at tenant, org or account root?
- Absence test answers NO across the in-scope estate: Is there no activation, time-bound or approval step?
- Absence test answers NO across the in-scope estate: Is that population larger than a named break-glass set?
- The paired capability B1 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Permanent Global Admin or Owner at Tenant Root Group.
- AWS: IAM users or SSO groups with AdministratorAccess on the management account, standing.
- GCP: Users with roles/owner or organizationAdmin at org, standing.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Removing root-equivalent privilege before operational roles and emergency paths are validated may block incident response.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-B1, B1, B2, B4, B5, A5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-IDENTITY-AP-B2-01

ANTI-PATTERN · DOMAIN B

Retire Cloud-Local Human Identity as the Primary Access Path

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-B2 · Pair: B2 · Supporting/reuse: B1, B5, A5
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-MS-CAF-IDENTITY, SRC-AWS-IDENTITY-CENTER, SRC-GCP-LZ, SRC-CIS-AWS, SRC-CIS-AZURE
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-B2 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

People log in with cloud-native users disconnected from the corporate IdP. Leavers keep access. Joiners get a second identity to babysit. This tactic provides the controlled remediation mechanism for the locked AP-B2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of local cloud users as primary identity and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: corporate identity federation with joiner, mover and leaver lifecycle enforcement.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-B2 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- cloud-local human identity inventory
- federation and identity-linking configuration
- credential revocation and exception record
- sign-in and deprovisioning test evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are cloud-local human users the normal way to access the estate?
- Absence test answers NO across the in-scope estate: Does leaver processing in the corporate IdP leave cloud access intact?
- Absence test answers NO across the in-scope estate: Are shared logins (team@, admin@) in use?
- The paired capability B2 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Cloud-only Entra users for staff; shared admin mailboxes.
- AWS: IAM users with passwords/keys as the daily path; unused Identity Center.
- GCP: Consumer Gmail or unmanaged Google users on org IAM.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Identity cutover can strand users or preserve duplicate access if federation and deprovisioning are not tested together.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-B2, B2, B1, B5, A5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-IDENTITY-AP-B3-01

ANTI-PATTERN · DOMAIN B

Discover, Revoke and Replace Long-Lived Keys

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-B3 · Pair: B3 · Supporting/reuse: E4, H2, H5
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-GCP-FOUNDATIONS, SRC-AWS-SRA, SRC-CIS-AWS, SRC-CIS-GCP, SRC-CIS-AZURE
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-B3 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Access keys, client secrets and downloaded service-account keys are how automation and people authenticate. Rotation is a wish. This tactic provides the controlled remediation mechanism for the locked AP-B3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of long-lived keys as identity and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Replace Long-Lived Credentials with Workload Identity.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-B3 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- machine identity inventory
- federation/managed-identity configuration
- key and secret revocation log
- credential-lifetime test results
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are long-lived access keys or JSON service-account keys the default for workloads or humans?
- Absence test answers NO across the in-scope estate: Are keys older than policy (or unaged) still valid?
- Absence test answers NO across the in-scope estate: Do pipelines store cloud credentials in variables rather than federate?
- The paired capability B3 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: SP client secrets in ADO/GitHub; unused managed identity.
- AWS: IAM user access keys for CI and humans; keys never rotated.
- GCP: Downloaded SA JSON keys in repos or Secret Manager used as identity.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Premature key revocation can stop pipelines and production integrations.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-B3, B3, E4, H2, H5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-IDENTITY-AP-B4-01

ANTI-PATTERN · DOMAIN B

Remove Unscoped Root-Level Owner Access

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-B4 · Pair: B4 · Supporting/reuse: A4, B2, G1
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-MS-CAF-IDENTITY, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY, SRC-CIS-AZURE
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-B4 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Application teams receive Owner, Editor or AdministratorAccess at the organization or management-group root 'so they can work'. Guardrails cannot hold. This tactic provides the controlled remediation mechanism for the locked AP-B4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of unscoped owner at root and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Enforce Least Privilege Through the Resource Hierarchy.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-B4 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- role model and inheritance design
- root-level assignment inventory
- rightsizing decisions
- effective-access verification export
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Do application teams hold owner-equivalent rights at the organization or management-group root?
- Absence test answers NO across the in-scope estate: Can they disable policy, networking or logging as a side effect of that grant?
- Absence test answers NO across the in-scope estate: Is there no alternative scoped role for daily delivery?
- The paired capability B4 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: App groups assigned Owner at Tenant Root or intermediate MG.
- AWS: Dev SSO group with AdministratorAccess on * or on the root OU.
- GCP: App groups with roles/editor or owner on the organization.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Role reduction based only on assigned permissions can miss real operational dependencies.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-B4, B4, A4, B2, G1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-IDENTITY-AP-B5-01

ANTI-PATTERN · DOMAIN B

Create or Repair Missing and Unmonitored Break-Glass

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-B5 · Pair: B5 · Supporting/reuse: A5, F3, E2
PRIMARY OWNER	Identity and Access Owner
SUPPORTING ROLES	Cloud Platform, Security Operations and Application Owners
APPROVED SOURCE IDS	SRC-MS-ENTRA-PIM, SRC-AWS-SRA, SRC-CIS-AZURE, SRC-CIS-AWS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-B5 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Either emergency access does not exist, or it exists and nobody would notice if it were used — or abused. This tactic provides the controlled remediation mechanism for the locked AP-B5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of unmonitored or missing break-glass and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Establish Monitored Break-Glass Access.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-B5 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- emergency identity set
- dual-control operating procedure
- alert and escalation configuration
- scheduled activation-test record
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is there no designed emergency-access path?
- Absence test answers NO across the in-scope estate: Is emergency access used as a daily convenience account?
- Absence test answers NO across the in-scope estate: Would use of emergency access produce no alert?
- The paired capability B5 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No break-glass; or Global Admin shared and unalerted.
- AWS: Root used as a shared login; no CloudTrail alarm on root.
- GCP: Super-admin used daily; no audit-log alert.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Break-glass credentials can become a permanent bypass if normal use is not prevented and monitored.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-B5, B5, A5, F3, E2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

Domain C - Resource organization

Namespace: RESOURCE · 10 tactic objects · Primary ownership: Cloud Platform Engineering Owner

Workshop themes

- Does the hierarchy encode policy, or is it a filing cabinet?
- Where does the platform landing zone end and an application landing zone begin?
- How is a new subscription, account or project born?

Domain control intent

Use the RESOURCE catalogue only after an exact Domain C finding is locked. Capability-building tactics establish the target mechanism; anti-pattern tactics contain and correct the harmful observed state. Supporting roles: Cloud Governance, FinOps and Application Platform Teams.

TAC-RESOURCE-C1-01

CAPABILITY · DOMAIN C

Design a Policy-Bearing Resource Hierarchy

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: C1 · Pair: AP-C1 · Supporting/reuse: G1, A1, C5
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-RESOURCE-ORG, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY, SRC-MS-AZURE-POLICY, SRC-AWS-SCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that C1 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-C1 finding requires the capability as the replacement control.

Control purpose and rationale

Management groups, OUs or folders are the policy inheritance spine. Placement of a workload decides its guardrails, not a wiki page. This tactic provides the controlled remediation mechanism for the locked C1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for C1 using live control-plane inventory.
- Design the mechanism: Design a Policy-Bearing Resource Hierarchy; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- target hierarchy model
- policy inheritance map
- placement and migration plan
- post-change hierarchy export
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Does every in-scope subscription, account or project sit under a designed hierarchy node?
- Evidence answers YES: Is policy inherited from those nodes rather than applied one-by-one as a hobby?
- Evidence answers YES: Can the platform explain what moving a workload to another node would change?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Management group tree from Tenant Root; Azure Policy assignments at MG.
- AWS: OU tree; SCPs attached to OUs, not only to individual accounts.
- GCP: Folder tree; Organization Policy on org/folders, not only on projects.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Moving resources or accounts between hierarchy nodes can change inherited policy and access.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess C1, AP-C1, G1, A1, C5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-RESOURCE-C2-01

CAPABILITY · DOMAIN C

Separate Platform and Application Landing Zones

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: C2 · Pair: AP-C2 · Supporting/reuse: A2, D1, E5
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-LZ, SRC-MS-CAF-RESOURCE-ORG, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that C2 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-C2 finding requires the capability as the replacement control.

Control purpose and rationale

Identity, connectivity, management and security sit in platform landing zones. Applications sit in application landing zones that consume those services. This tactic provides the controlled remediation mechanism for the locked C2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for C2 using live control-plane inventory.
- Design the mechanism: Separate Platform and Application Landing Zones; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- platform/application boundary design
- shared-service consumption contracts
- resource migration record
- segregation verification
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are platform services (identity, hub network, logging, security) separated from application workloads?
- Evidence answers YES: Do application landing zones consume shared services rather than rebuild them?
- Evidence answers YES: Is ownership of platform vs application landing zones named?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: CAF platform MGs/subscriptions (Identity, Connectivity, Management) vs Corp/Online app MGs.
- AWS: Log Archive, Audit, Network, Identity accounts vs workload OUs (Control Tower / custom).
- GCP: Bootstrap, logging, networking, security folders vs application folders.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Shared dependencies may be severed if platform services are separated without explicit contracts.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess C2, AP-C2, A2, D1, E5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-RESOURCE-C3-01

CAPABILITY · DOMAIN C

Enforce Naming and Tagging at Creation Time

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: C3 · Pair: AP-C3 · Supporting/reuse: G4, H2, F2
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-RESOURCE-ORG, SRC-MS-CAF-GOVERNANCE, SRC-AWS-ORG-STRATEGY, SRC-GCP-ORGPOLICY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that C3 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-C3 finding requires the capability as the replacement control.

Control purpose and rationale

A naming and tagging standard exists, is machine-enforced at vending time, and untagged or illegally named resources are visible as exceptions. This tactic provides the controlled remediation mechanism for the locked C3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for C3 using live control-plane inventory.
- Design the mechanism: Enforce Naming and Tagging at Creation Time; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- versioned naming/tag standard
- create-time policy or pipeline rules
- exception register
- violation and remediation report
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a documented naming and tagging standard for subscriptions, accounts, projects and resources?
- Evidence answers YES: Is it enforced at create-time (policy, SCP or vending pipeline), not only in a slide?
- Evidence answers YES: Are violations tracked and remediated rather than accepted as noise?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Azure Policy required-tags; naming via Bicep/AVM or subscription vending.
- AWS: SCP / Config / Tag Policies; Control Tower or AFT account naming.
- GCP: Org policy, labels, project-id convention in the project factory.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Rigid metadata rules can block legitimate provisioning or break integrations using existing names.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess C3, AP-C3, G4, H2, F2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-RESOURCE-C4-01

CAPABILITY · DOMAIN C

Implement Governed Isolation-Unit Vending

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: C4 · Pair: AP-C4 · Supporting/reuse: H2, H4, C3
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-AWS-AFT, SRC-AWS-CT, SRC-GCP-FOUNDATIONS, SRC-AZURE-ALZ-GITHUB
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that C4 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-C4 finding requires the capability as the replacement control.

Control purpose and rationale

New isolation units are created by a pipeline or service catalog, with identity, network, policy and logging attached at birth — not by a portal click and a hope. This tactic provides the controlled remediation mechanism for the locked C4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for C4 using live control-plane inventory.
- Design the mechanism: Implement Governed Isolation-Unit Vending; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- subscription/account/project product definition
- vending workflow and code
- baseline attachment tests
- issued-unit audit trail
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are new subscriptions, accounts or projects created through a vending path rather than ad-hoc portal clicks?
- Evidence answers YES: Does the vended unit land in the correct hierarchy node with baseline policy, identity and logging?
- Evidence answers YES: Can the platform show the last N vended units and their owners?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Subscription vending (Azure LZ accelerator, ALZ, service catalog).
- AWS: Account Factory / AFT / custom Organizations pipeline.
- GCP: Project factory (Terraform), Seed + CI; no ad-hoc console projects.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Automating an incomplete baseline scales the defect across every new landing zone.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess C4, AP-C4, H2, H4, C3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-RESOURCE-C5-01

CAPABILITY · DOMAIN C

Separate Production and Non-Production Boundaries

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: C5 · Pair: AP-C5 · Supporting/reuse: D5, B4, G1
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-RESOURCE-ORG, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY, SRC-NIST-800-53
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that C5 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-C5 finding requires the capability as the replacement control.

Control purpose and rationale

Production is a different landing-zone node from non-production. Blast radius, identity and data paths respect that line. This tactic provides the controlled remediation mechanism for the locked C5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for C5 using live control-plane inventory.
- Design the mechanism: Separate Production and Non-Production Boundaries; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- environment classification rules
- separation architecture
- migration and access-cleanup record
- cross-boundary test results
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are production and non-production in distinct hierarchy nodes or landing zones?
- Evidence answers YES: Can non-production identities not administer production by default?
- Evidence answers YES: Is data-path isolation (network, identity, key) designed, not accidental?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Corp-prod vs Corp-nonprod MGs; separate subscriptions; no shared Owner group.
- AWS: Prod vs SDLC OUs; SCPs differ; no shared admin permission set.
- GCP: Prod vs nonprod folders; VPC-SC / IAM differ by folder.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Environment separation can alter data flows, release processes and operational ownership.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess C5, AP-C5, D5, B4, G1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-RESOURCE-AP-C1-01

ANTI-PATTERN · DOMAIN C

Restructure Flat Subscription, Account or Project Sprawl

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-C1 · Pair: C1 · Supporting/reuse: G1, A1, C5
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-RESOURCE-ORG, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-C1 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Hundreds of subscriptions, accounts or projects hang off the root. Policy cannot inherit. Nobody can draw the map. This tactic provides the controlled remediation mechanism for the locked AP-C1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of flat subscription or account sprawl and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Design a Policy-Bearing Resource Hierarchy.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-C1 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- target hierarchy model
- policy inheritance map
- placement and migration plan
- post-change hierarchy export
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Do most isolation units sit directly under the tenant, org root or a single catch-all node?
- Absence test answers NO across the in-scope estate: Is the hierarchy unused as a policy spine?
- Absence test answers NO across the in-scope estate: Can the platform not produce a current map of nodes and owners?
- The paired capability C1 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: All subscriptions under Tenant Root Group.
- AWS: All accounts in Root; empty OU design.
- GCP: All projects directly under the organization.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Moving resources or accounts between hierarchy nodes can change inherited policy and access.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-C1, C1, G1, A1, C5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-RESOURCE-AP-C2-01

ANTI-PATTERN · DOMAIN C

Extract Applications from Platform Landing Zones

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-C2 · Pair: C2 · Supporting/reuse: A2, D1, E5
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-LZ, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-C2 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Business systems share the connectivity, identity or management subscription. Platform change freezes the business; business change risks the platform. This tactic provides the controlled remediation mechanism for the locked AP-C2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of applications in the platform landing zone and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Separate Platform and Application Landing Zones.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-C2 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- platform/application boundary design
- shared-service consumption contracts
- resource migration record
- segregation verification
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Do application workloads share platform subscriptions, accounts or projects?
- Absence test answers NO across the in-scope estate: Would a platform rebuild collide with application data?
- Absence test answers NO across the in-scope estate: Are application teams granted rights on platform landing zones to 'get things done'?
- The paired capability C2 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: App resource groups in Connectivity or Management subscriptions.
- AWS: Workload VPCs in the Network or Audit account.
- GCP: App GKE in the shared-vpc host or logging project.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Shared dependencies may be severed if platform services are separated without explicit contracts.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-C2, C2, A2, D1, E5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-RESOURCE-AP-C3-01

ANTI-PATTERN · DOMAIN C

Replace Ad-Hoc Naming and Tag Theatre with Enforced Metadata

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-C3 · Pair: C3 · Supporting/reuse: G4, H2, F2
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-RESOURCE-ORG, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-C3 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Names are local jokes. Tags exist in a PDF. Create-time enforcement is absent. Search, cost and incident response guess. This tactic provides the controlled remediation mechanism for the locked AP-C3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of ad-hoc naming and tag theatre and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Enforce Naming and Tagging at Creation Time.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-C3 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- versioned naming/tag standard
- create-time policy or pipeline rules
- exception register
- violation and remediation report
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Do names and tags differ by team with no enforced standard?
- Absence test answers NO across the in-scope estate: Is the tagging standard documentation-only?
- Absence test answers NO across the in-scope estate: Are untagged resources treated as acceptable?
- The paired capability C3 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No required-tag policy; subscription names like 'test2-final'.
- AWS: No tag policies; account emails as the only identifier.
- GCP: No label convention; project IDs are random or personal.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Rigid metadata rules can block legitimate provisioning or break integrations using existing names.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-C3, C3, G4, H2, F2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-RESOURCE-AP-C4-01

ANTI-PATTERN · DOMAIN C

Replace ClickOps Birth with a Governed Vending Path

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-C4 · Pair: C4 · Supporting/reuse: H2, H4, C3
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-AWS-AFT, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-C4 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Subscriptions, accounts or projects are created in the portal, emailed into existence, or copied from a neighbour. Baseline is optional. This tactic provides the controlled remediation mechanism for the locked AP-C4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of clickops birth of isolation units and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Implement Governed Isolation-Unit Vending.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-C4 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- subscription/account/project product definition
- vending workflow and code
- baseline attachment tests
- issued-unit audit trail
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is the normal create path a portal click or a ticket to a human who clicks?
- Absence test answers NO across the in-scope estate: Do new units appear without policy, logging or network baseline?
- Absence test answers NO across the in-scope estate: Is there no record of who requested the unit and why?
- The paired capability C4 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Portal-created subscriptions not in the vending app.
- AWS: Organizations 'Add account' by hand; no AFT/Control Tower.
- GCP: Console 'create project' by developers.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Automating an incomplete baseline scales the defect across every new landing zone.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-C4, C4, H2, H4, C3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-RESOURCE-AP-C5-01

ANTI-PATTERN · DOMAIN C

Split Mixed Environments and Close Cross-Environment Paths

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-C5 · Pair: C5 · Supporting/reuse: D5, B4, G1
PRIMARY OWNER	Cloud Platform Engineering Owner
SUPPORTING ROLES	Cloud Governance, FinOps and Application Platform Teams
APPROVED SOURCE IDS	SRC-MS-CAF-RESOURCE-ORG, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-C5 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Production, test and playground share a subscription, account or folder. A playground identity can reach production data. This tactic provides the controlled remediation mechanism for the locked AP-C5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of mixed environments in one boundary and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Separate Production and Non-Production Boundaries.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-C5 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- environment classification rules
- separation architecture
- migration and access-cleanup record
- cross-boundary test results
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Do production and non-production share the same isolation unit?
- Absence test answers NO across the in-scope estate: Can non-production identities reach production data or keys?
- Absence test answers NO across the in-scope estate: Is 'we use resource groups / VPCs instead' used to avoid a landing-zone line?
- The paired capability C5 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Prod and dev resource groups in one subscription with shared Owner.
- AWS: Prod and sandbox in one account; one admin role.
- GCP: Prod and playground in one project or shared folder IAM.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Environment separation can alter data flows, release processes and operational ownership.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-C5, C5, D5, B4, G1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

Domain D - Network topology & connectivity

Namespace: NETWORK · 10 tactic objects · Primary ownership: Cloud Network Owner

Workshop themes

- Where is the hub, and what is forced through it?
- Who owns hybrid connectivity, DNS and inspection?
- Is private-by-default a control, or a preference?

Domain control intent

Use the NETWORK catalogue only after an exact Domain D finding is locked. Capability-building tactics establish the target mechanism; anti-pattern tactics contain and correct the harmful observed state. Supporting roles: Cloud Platform, Security Architecture and Network Operations.

TAC-NETWORK-D1-01

CAPABILITY · DOMAIN D

Establish a Governed Hub and Inspection Topology

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: D1 · Pair: AP-D1 · Supporting/reuse: D2, D5, E2
PRIMARY OWNER	Cloud Network Owner
SUPPORTING ROLES	Cloud Platform, Security Architecture and Network Operations
APPROVED SOURCE IDS	SRC-MS-CAF-NETWORK, SRC-AWS-SRA, SRC-GCP-SHARED-VPC, SRC-GCP-LZ, SRC-CISA-CLOUD-TRA
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that D1 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-D1 finding requires the capability as the replacement control.

Control purpose and rationale

A designed hub (hub-spoke, Virtual WAN, Transit Gateway, Shared VPC) exists. Spoke-to-spoke and egress paths are intentional. Inspection is a placement, not a hope. This tactic provides the controlled remediation mechanism for the locked D1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for D1 using live control-plane inventory.
- Design the mechanism: Establish a Governed Hub and Inspection Topology; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- approved hub topology
- route and inspection policy
- edge migration plan
- flow and egress verification
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a designed hub that spokes must use for shared and egress traffic?
- Evidence answers YES: Are inspection points (firewall, IDS, web proxy) placed on those forced paths?
- Evidence answers YES: Is spoke-to-spoke traffic an explicit pattern rather than a mesh accident?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Hub-spoke or vWAN; Azure Firewall / NVA; spoke peering without use-remote-gateway exceptions unlisted.
- AWS: Transit Gateway / Cloud WAN; inspection VPC; no VPC-peering spaghetti as the primary pattern.
- GCP: Shared VPC + hub; Cloud Firewall / NGFW; no project-level public default.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Centralized inspection can introduce latency, asymmetric routing or a shared failure domain.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess D1, AP-D1, D2, D5, E2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-NETWORK-D2-01

CAPABILITY · DOMAIN D

Centralize Ownership of Hybrid Connectivity

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: D2 · Pair: AP-D2 · Supporting/reuse: D1, D3, F3
PRIMARY OWNER	Hybrid Network Service Owner
SUPPORTING ROLES	Cloud Network, Network Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-NETWORK, SRC-AWS-SRA, SRC-GCP-LZ, SRC-CISA-CLOUD-TRA
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that D2 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-D2 finding requires the capability as the replacement control.

Control purpose and rationale

ExpressRoute, Direct Connect, Interconnect, VPN and SD-WAN land in the platform, not in an application subscription. Ownership, redundancy and failover are named. This tactic provides the controlled remediation mechanism for the locked D2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for D2 using live control-plane inventory.
- Design the mechanism: Centralize Ownership of Hybrid Connectivity; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- hybrid circuit and tunnel inventory
- ownership/RACI
- redundancy and failover design
- failover test evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Do hybrid circuits terminate in a platform connectivity landing zone?
- Evidence answers YES: Are redundancy, failover and who-to-call documented and tested?
- Evidence answers YES: Can application teams not create competing hybrid paths as a side door?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: ExpressRoute / VPN Gateway in Connectivity subscription; no app-level ER circuits.
- AWS: DX Gateway / VPN on the network account; TGW attachments governed.
- GCP: Dedicated/Partner Interconnect on the host project; no per-app interconnects.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Connectivity changes can isolate cloud or on-premises workloads if failover is untested.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess D2, AP-D2, D1, D3, F3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-NETWORK-D3-01

CAPABILITY · DOMAIN D

Provide Central Private DNS Resolution

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: D3 · Pair: AP-D3 · Supporting/reuse: D2, D4, F4
PRIMARY OWNER	Cloud Network Owner
SUPPORTING ROLES	Cloud Platform, Security Architecture and Network Operations
APPROVED SOURCE IDS	SRC-MS-CAF-NETWORK, SRC-AWS-SRA, SRC-GCP-LZ
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that D3 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-D3 finding requires the capability as the replacement control.

Control purpose and rationale

Private DNS is a platform service. Resolution of on-premises, PaaS private endpoints and landing-zone names is consistent. Split-brain is a tracked exception. This tactic provides the controlled remediation mechanism for the locked D3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for D3 using live control-plane inventory.
- Design the mechanism: Provide Central Private DNS Resolution; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- DNS authority and zone design
- resolver and forwarding configuration
- exception register
- hybrid/private-endpoint resolution tests
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is private DNS administered as a platform service rather than per application?
- Evidence answers YES: Do private endpoints and hybrid names resolve consistently in every landing zone?
- Evidence answers YES: Are rogue DNS forwarders inventoried?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Private DNS zones in Connectivity; Azure Policy for private-endpoint DNS; inbound/outbound resolvers.
- AWS: Route 53 private hosted zones + Resolver rules in the network account.
- GCP: Cloud DNS private zones on the host project; inbound/outbound forwarding.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	DNS migration errors can create broad, difficult-to-diagnose application failures.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess D3, AP-D3, D2, D4, F4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-NETWORK-D4-01

CAPABILITY · DOMAIN D

Enforce Private-by-Default Service Access

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: D4 · Pair: AP-D4 · Supporting/reuse: G2, D3, E1
PRIMARY OWNER	Cloud Network Owner
SUPPORTING ROLES	Cloud Platform, Security Architecture and Network Operations
APPROVED SOURCE IDS	SRC-MS-CAF-NETWORK, SRC-MS-MCSB-V1, SRC-AWS-SCP, SRC-GCP-ORGPOLICY, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that D4 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-D4 finding requires the capability as the replacement control.

Control purpose and rationale

Public endpoints are denied or exception-gated. PaaS public access is off unless an expiry-bound exemption exists. This tactic provides the controlled remediation mechanism for the locked D4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for D4 using live control-plane inventory.
- Design the mechanism: Enforce Private-by-Default Service Access; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- public-access denial policy
- private endpoint/service controls
- public exposure inventory
- time-bound exception and closure evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is public network access denied by policy for relevant services unless exempted?
- Evidence answers YES: Are remaining public endpoints inventoried with owner and expiry?
- Evidence answers YES: Is internet egress a controlled hub path rather than every NIC for itself?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Azure Policy deny public IP / public blob / public Key Vault; Firewall / NAT at hub.
- AWS: SCP deny public S3/SG 0.0.0.0/0; centralized egress via TGW + firewall.
- GCP: Org policy constrainPublicIp / disable public buckets; Cloud NAT at hub.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Disabling public access before private paths and DNS are ready can cause an outage.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess D4, AP-D4, G2, D3, E1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-NETWORK-D5-01

CAPABILITY · DOMAIN D

Enforce Landing-Zone Network Segmentation

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: D5 · Pair: AP-D5 · Supporting/reuse: C5, D1, B4
PRIMARY OWNER	Cloud Network Owner
SUPPORTING ROLES	Cloud Platform, Security Architecture and Network Operations
APPROVED SOURCE IDS	SRC-MS-CAF-NETWORK, SRC-NIST-800-207, SRC-AWS-SRA, SRC-GCP-SHARED-VPC, SRC-NCSC-CLOUD-PRINCIPLES
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that D5 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-D5 finding requires the capability as the replacement control.

Control purpose and rationale

Application landing zones are network segments, not names. Identity and network together define who can talk to whom. This tactic provides the controlled remediation mechanism for the locked D5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for D5 using live control-plane inventory.
- Design the mechanism: Enforce Landing-Zone Network Segmentation; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- segmentation policy and zone model
- approved connectivity matrix
- peering/attachment cleanup record
- reachability and isolation tests
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Does each application landing zone have a defined network segment and peering model?
- Evidence answers YES: Are east-west rules explicit (allow-lists), not 'all spokes can talk'?
- Evidence answers YES: Is production segmented from non-production on the wire, not only in a naming standard?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Spoke VNets per LZ; NSG/Azure Firewall policies; no prod-nonprod peering by default.
- AWS: Account+VPC per LZ; SG/NACL + TGW route tables isolate prod.
- GCP: Service projects + VPC-SC perimeters; Shared VPC subnet isolation.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Removing implicit connectivity can expose undocumented application dependencies.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess D5, AP-D5, C5, D1, B4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-NETWORK-AP-D1-01

ANTI-PATTERN · DOMAIN D

Consolidate Per-Application Internet Edges

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-D1 · Pair: D1 · Supporting/reuse: D2, D5, E2
PRIMARY OWNER	Cloud Network Owner
SUPPORTING ROLES	Cloud Platform, Security Architecture and Network Operations
APPROVED SOURCE IDS	SRC-MS-CAF-NETWORK, SRC-AWS-SRA, SRC-GCP-SHARED-VPC
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-D1 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Every team brings its own public IP, firewall flavour and VPN. The platform cannot see, inspect or retire paths. This tactic provides the controlled remediation mechanism for the locked AP-D1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of per-application internet edge and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Establish a Governed Hub and Inspection Topology.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-D1 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- approved hub topology
- route and inspection policy
- edge migration plan
- flow and egress verification
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Do application teams create their own public IPs, firewalls or VPNs as the normal path?
- Absence test answers NO across the in-scope estate: Is egress inspection optional per team?
- Absence test answers NO across the in-scope estate: Is there no inventory of internet edges?
- The paired capability D1 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Public IPs on app VMs; app-level Azure Firewalls; no hub.
- AWS: IGW on every VPC; no TGW; SG 0.0.0.0/0 common.
- GCP: Public IPs on GCE; per-project Cloud NAT/VPN.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Centralized inspection can introduce latency, asymmetric routing or a shared failure domain.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-D1, D1, D2, D5, E2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-NETWORK-AP-D2-01

ANTI-PATTERN · DOMAIN D

Segment the Flat Global Network

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-D2 · Pair: D2 · Supporting/reuse: D5, D1, B4, G2
PRIMARY OWNER	Hybrid Network Service Owner
SUPPORTING ROLES	Cloud Network, Network Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-NETWORK, SRC-AWS-SRA, SRC-NIST-800-207
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-D2 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Everything can route to everything. Segmentation is a slide. A compromised sandbox reaches production. This tactic provides the controlled remediation mechanism for the locked AP-D2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of flat global network and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: explicit landing-zone segmentation enforced through routing, firewall and identity boundaries.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-D2 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- current reachability and trust map
- target segmentation and connectivity matrix
- route/firewall/identity enforcement changes
- cross-zone isolation test evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Can every spoke route to every other spoke by default?
- Absence test answers NO across the in-scope estate: Is production reachable from non-production on the network?
- Absence test answers NO across the in-scope estate: Are NSG/SG/firewall rules effectively allow-any?
- The paired capability D2 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Full-mesh VNet peering; AllowVnetInbound NSGs.
- AWS: TGW default route table associates all; 0.0.0.0/0 SG.
- GCP: One big Shared VPC with default-allow and no VPC-SC.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Network segmentation can disrupt undocumented east-west dependencies or emergency access paths.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-D2, D2, D5, D1, B4, G2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-NETWORK-AP-D3-01

ANTI-PATTERN · DOMAIN D

Eliminate Split-Brain and Unowned Private DNS

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-D3 · Pair: D3 · Supporting/reuse: D2, D4, F4
PRIMARY OWNER	Cloud Network Owner
SUPPORTING ROLES	Cloud Platform, Security Architecture and Network Operations
APPROVED SOURCE IDS	SRC-MS-CAF-NETWORK, SRC-GCP-LZ, SRC-AWS-SRA
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-D3 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Each team runs DNS. Private endpoints do not resolve. Hybrid names work 'on my laptop'. Incident response cannot find things. This tactic provides the controlled remediation mechanism for the locked AP-D3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of split-brain or absent private dns and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Provide Central Private DNS Resolution.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-D3 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- DNS authority and zone design
- resolver and forwarding configuration
- exception register
- hybrid/private-endpoint resolution tests
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is private DNS missing, or different in every landing zone?
- Absence test answers NO across the in-scope estate: Do private endpoints fail to resolve without tribal knowledge?
- Absence test answers NO across the in-scope estate: Are hosts files and tribal resolvers in production use?
- The paired capability D3 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No central Private DNS; privatelink zones missing.
- AWS: No Resolver rules; each VPC has its own private zone or none.
- GCP: No Cloud DNS private zone; 169.254.169.254 tribal hacks.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	DNS migration errors can create broad, difficult-to-diagnose application failures.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-D3, D3, D2, D4, F4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-NETWORK-AP-D4-01

ANTI-PATTERN · DOMAIN D

Close Public-by-Default Endpoints

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-D4 · Pair: D4 · Supporting/reuse: G2, D3, E1
PRIMARY OWNER	Cloud Network Owner
SUPPORTING ROLES	Cloud Platform, Security Architecture and Network Operations
APPROVED SOURCE IDS	SRC-MS-MCSB-V1, SRC-GCP-ORGPOLICY, SRC-AWS-SCP, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-D4 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Storage, Kubernetes API, databases and jump hosts are public unless someone remembers to tick a box. Policy does not deny it. This tactic provides the controlled remediation mechanism for the locked AP-D4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of public as the default and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Enforce Private-by-Default Service Access.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-D4 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- public-access denial policy
- private endpoint/service controls
- public exposure inventory
- time-bound exception and closure evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are public endpoints allowed by default on data, control-plane or jump services?
- Absence test answers NO across the in-scope estate: Is there no deny policy for public access?
- Absence test answers NO across the in-scope estate: Is the public inventory unknown?
- The paired capability D4 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Storage public blobs; public AKS API; no deny policy.
- AWS: Public S3, public RDS, 22/3389 from 0.0.0.0/0.
- GCP: Public buckets, public GKE masters, 0.0.0.0/0 firewall.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Disabling public access before private paths and DNS are ready can cause an outage.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-D4, D4, G2, D3, E1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-NETWORK-AP-D5-01

ANTI-PATTERN · DOMAIN D

Dismantle the Unmanaged Peering Mesh

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-D5 · Pair: D5 · Supporting/reuse: C5, D1, B4
PRIMARY OWNER	Cloud Network Owner
SUPPORTING ROLES	Cloud Platform, Security Architecture and Network Operations
APPROVED SOURCE IDS	SRC-MS-CAF-NETWORK, SRC-AWS-SRA, SRC-GCP-SHARED-VPC
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-D5 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Peerings, attachments and interconnects accumulate. Nobody can draw the current topology. A delete is an outage lottery. This tactic provides the controlled remediation mechanism for the locked AP-D5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of unmanaged peering mesh and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Enforce Landing-Zone Network Segmentation.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-D5 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- segmentation policy and zone model
- approved connectivity matrix
- peering/attachment cleanup record
- reachability and isolation tests
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is the current network topology not drawable from inventory?
- Absence test answers NO across the in-scope estate: Do peerings and attachments exist without an owner or change record?
- Absence test answers NO across the in-scope estate: Would removing a 'temporary' path have unknown blast radius?
- The paired capability D5 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: VNet peerings with no CMDB; undocumented ER authorizations.
- AWS: VPC peering + TGW attachments unlabelled; unused DX VIFs.
- GCP: VPC peering spaghetti; leftover interconnect VLANs.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Removing implicit connectivity can expose undocumented application dependencies.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-D5, D5, C5, D1, B4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

Domain E - Security baseline

Namespace: SECURITY · 10 tactic objects · Primary ownership: Cloud Security Owner

Workshop themes

- What is prevented by the platform, versus detected after the fact?
- Where do logs, detections and keys live — and who operates them?
- Are secrets and encryption a control, or a developer preference?

Domain control intent

Use the SECURITY catalogue only after an exact Domain E finding is locked. Capability-building tactics establish the target mechanism; anti-pattern tactics contain and correct the harmful observed state. Supporting roles: Security Operations, Cloud Platform and Application Security.

TAC-SECURITY-E1-01

CAPABILITY · DOMAIN E

Deploy a Preventive Landing-Zone Security Baseline

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: E1 · Pair: AP-E1 · Supporting/reuse: G1, G2, H1
PRIMARY OWNER	Cloud Security Owner
SUPPORTING ROLES	Security Operations, Cloud Platform and Application Security
APPROVED SOURCE IDS	SRC-MS-MCSB-V1, SRC-MS-CAF-SECURITY, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that E1 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-E1 finding requires the capability as the replacement control.

Control purpose and rationale

A defined security baseline is enforced at the landing zone (policy, SCP, org policy), not offered as a starter template that teams may ignore. This tactic provides the controlled remediation mechanism for the locked E1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for E1 using live control-plane inventory.
- Design the mechanism: Deploy a Preventive Landing-Zone Security Baseline; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- versioned security baseline
- root/hierarchy policy assignments
- exception register
- coverage and enforcement export
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is a security baseline assigned to every in-scope landing zone at birth?
- Evidence answers YES: Are high-severity misconfigurations denied rather than only reported?
- Evidence answers YES: Is the baseline versioned and owned by security + platform together?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Azure Policy security initiative (MCSB) assigned at MG with deny/deployIfNotExists.
- AWS: SCPs + Control Tower / Config conformance pack; Security Hub standards.
- GCP: Organization Policy constraints + SCC Premium posture; essential org policies.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A broad deny baseline can block critical workloads if staged testing and exceptions are absent.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess E1, AP-E1, G1, G2, H1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-SECURITY-E2-01

CAPABILITY · DOMAIN E

Centralize Organization-Level Threat Detection

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: E2 · Pair: AP-E2 · Supporting/reuse: F1, F3, E5
PRIMARY OWNER	Security Operations Owner
SUPPORTING ROLES	Cloud Security, Cloud Platform and Incident Response
APPROVED SOURCE IDS	SRC-MS-CAF-SECURITY, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS, SRC-CISA-CLOUD-TRA
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that E2 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-E2 finding requires the capability as the replacement control.

Control purpose and rationale

Cloud-native detections (Defender, GuardDuty, SCC) are on at organization scope. Findings land in a SOC path, not in a per-subscription inbox nobody reads. This tactic provides the controlled remediation mechanism for the locked E2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for E2 using live control-plane inventory.
- Design the mechanism: Centralize Organization-Level Threat Detection; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- organization-level detector configuration
- central finding destination
- SOC ownership and triage runbook
- detection-routing test evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are native threat-detection services enabled at organization or tenant scope?
- Evidence answers YES: Do findings route to a named SOC or detection owner with an SLA?
- Evidence answers YES: Are silent subscriptions, accounts or projects (detection off) inventoried as exceptions?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Defender for Cloud / Defender XDR at tenant; Sentinel or equivalent connected.
- AWS: GuardDuty org auto-enable, Security Hub, Detective; delegated admin in Audit account.
- GCP: Security Command Center at org; Event Threat Detection; findings exported.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Centralization without alert ownership can increase noise while preserving the same control gap.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess E2, AP-E2, F1, F3, E5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-SECURITY-E3-01

CAPABILITY · DOMAIN E

Operationalize Encryption and Key Management

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: E3 · Pair: AP-E3 · Supporting/reuse: E4, F4, B3
PRIMARY OWNER	Cloud Security Owner
SUPPORTING ROLES	Security Operations, Cloud Platform and Application Security
APPROVED SOURCE IDS	SRC-MS-MCSB-V1, SRC-AWS-WA-SECURITY, SRC-GCP-FOUNDATIONS, SRC-NCSC-CLOUD-PRINCIPLES, SRC-ISO-27017
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that E3 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-E3 finding requires the capability as the replacement control.

Control purpose and rationale

Data is encrypted with platform-managed or customer-managed keys that the landing zone actually uses. Keys are not in code, and CMK is not a slide. This tactic provides the controlled remediation mechanism for the locked E3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for E3 using live control-plane inventory.
- Design the mechanism: Operationalize Encryption and Key Management; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- data/key classification and design
- KMS/HSM configuration
- key-use and rotation evidence
- code/repository cleanup record
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is encryption at rest required by policy for data stores in scope?
- Evidence answers YES: If CMK is claimed, are keys in a platform key landing zone with rotation and access logs?
- Evidence answers YES: Are plaintext secrets or unencrypted disks treated as findings, not style?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: SSE required; Key Vault in platform; CMK where claimed; no keys in ARM parameters.
- AWS: S3/EBS/RDS encryption required by SCP/Config; KMS in security account; no plaintext SSM.
- GCP: CMEK/CSE as claimed; Cloud KMS in security folder; no unencrypted persistent disks as default.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Key replacement or rotation can render data inaccessible without tested recovery and dependency mapping.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess E3, AP-E3, E4, F4, B3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-SECURITY-E4-01

CAPABILITY · DOMAIN E

Implement Managed Secrets and Rotation

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: E4 · Pair: AP-E4 · Supporting/reuse: B3, H2, E3
PRIMARY OWNER	Cloud Security Owner
SUPPORTING ROLES	Security Operations, Cloud Platform and Application Security
APPROVED SOURCE IDS	SRC-MS-CAF-SECURITY, SRC-AWS-WA-SECURITY, SRC-GCP-FOUNDATIONS, SRC-NIST-800-53
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that E4 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-E4 finding requires the capability as the replacement control.

Control purpose and rationale

Secrets live in a vault service, are rotated, and are not the identity. Pipeline variables and wikis are not the secret store. This tactic provides the controlled remediation mechanism for the locked E4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for E4 using live control-plane inventory.
- Design the mechanism: Implement Managed Secrets and Rotation; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- secret inventory and ownership
- vault and access configuration
- rotation and revocation evidence
- pipeline integration tests
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a mandated secret store for platform and application secrets?
- Evidence answers YES: Are secrets rotated, access-logged, and free of long-lived cloud keys used as identity?
- Evidence answers YES: Do code, wikis and CI variables still hold production secrets?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Key Vault / App Config; no secrets in ADO lib groups as the primary store.
- AWS: Secrets Manager / SSM Parameter (secure); no secrets in CodeCommit or plain SSM.
- GCP: Secret Manager; no secrets in Cloud Build substitutions or repos.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Secret migration can interrupt automated jobs if consumers and refresh behavior are unknown.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess E4, AP-E4, B3, H2, E3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-SECURITY-E5-01

CAPABILITY · DOMAIN E

Establish the Security Operations Landing Zone and RACI

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: E5 · Pair: AP-E5 · Supporting/reuse: E2, F1, F3
PRIMARY OWNER	Cloud Security Operations Owner
SUPPORTING ROLES	SOC, Cloud Platform, Risk and Application Security
APPROVED SOURCE IDS	SRC-MS-CAF-SECURITY, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS, SRC-CISA-CLOUD-TRA
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that E5 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-E5 finding requires the capability as the replacement control.

Control purpose and rationale

Security tooling has a landing-zone home (audit/security subscription) and a RACI with the SOC. Security is not 'a marketplace product in each app team'. This tactic provides the controlled remediation mechanism for the locked E5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for E5 using live control-plane inventory.
- Design the mechanism: Establish the Security Operations Landing Zone and RACI; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- security tooling placement design
- platform/SOC RACI
- finding-routing workflow
- operational handoff and exercise evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a platform security landing zone that hosts org-level security services?
- Evidence answers YES: Is the SOC / CSIRT relationship named, including who triages cloud findings?
- Evidence answers YES: Are overlapping security tools inventoried rather than silently duplicated?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Security/Management subscription; Defender, Sentinel, Key Vault HSM as designed.
- AWS: Audit + Security Tooling accounts (Control Tower); delegated admins set.
- GCP: Security folder: SCC, KMS, Secret Manager; Essential Contacts for security.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Ambiguous ownership may persist even after tooling is centralized unless decision rights are explicit.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess E5, AP-E5, E2, F1, F3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-SECURITY-AP-E1-01

ANTI-PATTERN · DOMAIN E

Convert Optional Security into Mandatory Guardrails

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-E1 · Pair: E1 · Supporting/reuse: G1, G2, H1
PRIMARY OWNER	Cloud Security Owner
SUPPORTING ROLES	Security Operations, Cloud Platform and Application Security
APPROVED SOURCE IDS	SRC-MS-MCSB-V1, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-E1 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

The baseline is a PDF. Teams may enable Defender, GuardDuty or SCC 'when they are ready'. Most are not ready. This tactic provides the controlled remediation mechanism for the locked AP-E1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of optional security and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Deploy a Preventive Landing-Zone Security Baseline.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-E1 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- versioned security baseline
- root/hierarchy policy assignments
- exception register
- coverage and enforcement export
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is the security baseline advisory rather than assigned?
- Absence test answers NO across the in-scope estate: Can a landing zone be vended with threat detection off?
- Absence test answers NO across the in-scope estate: Is 'we'll add security later' visible in the last N vended units?
- The paired capability E1 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: MCSB assigned as Audit only; Defender off on most subscriptions.
- AWS: GuardDuty not org-enabled; no SCPs for encryption.
- GCP: SCC Standard or off; org policies unset.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A broad deny baseline can block critical workloads if staged testing and exceptions are absent.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-E1, E1, G1, G2, H1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-SECURITY-AP-E2-01

ANTI-PATTERN · DOMAIN E

Consolidate SIEM and Detection Islands

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-E2 · Pair: E2 · Supporting/reuse: F1, F3, E5
PRIMARY OWNER	Security Operations Owner
SUPPORTING ROLES	Cloud Security, Cloud Platform and Incident Response
APPROVED SOURCE IDS	SRC-MS-CAF-SECURITY, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-E2 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Each team has a log workspace, a GuardDuty detector, or a SCC project. Nobody can hunt across the estate. Retention is a guess. This tactic provides the controlled remediation mechanism for the locked AP-E2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of per-subscription siem islands and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Centralize Organization-Level Threat Detection.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-E2 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- organization-level detector configuration
- central finding destination
- SOC ownership and triage runbook
- detection-routing test evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are detections and security logs fragmented per landing zone with no org view?
- Absence test answers NO across the in-scope estate: Is there no delegated security administrator at organization scope?
- Absence test answers NO across the in-scope estate: Would a SOC hunt require asking every team for access?
- The paired capability E2 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Per-sub Log Analytics; Defender not connected to a central Sentinel.
- AWS: GuardDuty per-account without org; no delegated admin.
- GCP: SCC at project level only; no org-level findings.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Centralization without alert ownership can increase noise while preserving the same control gap.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-E2, E2, F1, F3, E5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-SECURITY-AP-E3-01

ANTI-PATTERN · DOMAIN E

Remove Keys from Code and Prove Real Key Use

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-E3 · Pair: E3 · Supporting/reuse: E4, F4, B3
PRIMARY OWNER	Cloud Security Owner
SUPPORTING ROLES	Security Operations, Cloud Platform and Application Security
APPROVED SOURCE IDS	SRC-MS-MCSB-V1, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-E3 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

CMK is claimed in architecture decks while disks use default keys and API keys sit in Git. Encryption is a brand. This tactic provides the controlled remediation mechanism for the locked AP-E3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of keys in code or unused cmk theatre and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Operationalize Encryption and Key Management.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-E3 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- data/key classification and design
- KMS/HSM configuration
- key-use and rotation evidence
- code/repository cleanup record
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are customer-managed keys claimed but not actually in use on data stores?
- Absence test answers NO across the in-scope estate: Do repositories or pipelines contain live cloud keys?
- Absence test answers NO across the in-scope estate: Is there no key-access logging or rotation?
- The paired capability E3 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Key Vault empty of CMK; secrets in Git; disks platform-default despite CMK policy on slides.
- AWS: KMS keys unused; AKIA keys in GitHub; S3 default encryption off.
- GCP: CMEK unused; JSON keys in Cloud Source; PD encryption default only.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Key replacement or rotation can render data inaccessible without tested recovery and dependency mapping.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-E3, E3, E4, F4, B3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-SECURITY-AP-E4-01

ANTI-PATTERN · DOMAIN E

Remove Secrets from Pipelines, Wikis and Spreadsheets

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-E4 · Pair: E4 · Supporting/reuse: B3, H2, E3
PRIMARY OWNER	Cloud Security Owner
SUPPORTING ROLES	Security Operations, Cloud Platform and Application Security
APPROVED SOURCE IDS	SRC-MS-MCSB-V1, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-E4 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

The secret store is Azure DevOps library, GitHub Actions secrets used as long-lived cloud keys, Confluence, or a shared spreadsheet. This tactic provides the controlled remediation mechanism for the locked AP-E4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of secrets in pipelines and wikis and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Implement Managed Secrets and Rotation.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-E4 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- secret inventory and ownership
- vault and access configuration
- rotation and revocation evidence
- pipeline integration tests
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are production secrets stored in CI variable groups, wikis or chat?
- Absence test answers NO across the in-scope estate: Are those values long-lived cloud credentials rather than federated identity?
- Absence test answers NO across the in-scope estate: Is rotation manual and overdue?
- The paired capability E4 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Client secrets in ADO variable groups; Key Vault unused.
- AWS: IAM keys in Actions secrets; Secrets Manager unused.
- GCP: SA JSON in Cloud Build; Secret Manager unused.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Secret migration can interrupt automated jobs if consumers and refresh behavior are unknown.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-E4, E4, B3, H2, E3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-SECURITY-AP-E5-01

ANTI-PATTERN · DOMAIN E

Replace After-the-Fact Security Tickets with Embedded Ownership

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-E5 · Pair: E5 · Supporting/reuse: E2, F1, F3
PRIMARY OWNER	Cloud Security Operations Owner
SUPPORTING ROLES	SOC, Cloud Platform, Risk and Application Security
APPROVED SOURCE IDS	SRC-MS-CAF-SECURITY, SRC-AWS-SRA, SRC-GCP-LZ
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-E5 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Workloads go live, then a security questionnaire is filed. Findings have no landing-zone owner. Platform and SOC point at each other. This tactic provides the controlled remediation mechanism for the locked AP-E5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of security as an after-the-fact ticket and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Establish the Security Operations Landing Zone and RACI.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-E5 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- security tooling placement design
- platform/SOC RACI
- finding-routing workflow
- operational handoff and exercise evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Does security review start after the workload is in production?
- Absence test answers NO across the in-scope estate: Are cloud findings unowned between platform and SOC?
- Absence test answers NO across the in-scope estate: Is there no security landing zone to host org controls?
- The paired capability E5 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No Security MG; Defender emails to a DL nobody triages.
- AWS: No Audit account; Security Hub findings ignored.
- GCP: No security folder; SCC email notifications off.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Ambiguous ownership may persist even after tooling is centralized unless decision rights are explicit.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-E5, E5, E2, F1, F3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

Domain F - Management & observability

Namespace: OPERATIONS · 10 tactic objects · Primary ownership: Cloud Platform Operations Owner

Workshop themes

- Where do activity, resource and diagnostic logs actually land?
- Can the platform list every subscription, account or project this week?
- If the platform burned down, what would restore it?

Domain control intent

Use the OPERATIONS catalogue only after an exact Domain F finding is locked. Capability-building tactics establish the target mechanism; anti-pattern tactics contain and correct the harmful observed state. Supporting roles: SRE/Operations, Security Operations and Service Owners.

TAC-OPERATIONS-F1-01

CAPABILITY · DOMAIN F

Centralize and Protect Activity and Audit Logs

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: F1 · Pair: AP-F1 · Supporting/reuse: E2, F3, G5
PRIMARY OWNER	Cloud Platform Operations Owner
SUPPORTING ROLES	SRE/Operations, Security Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-MANAGEMENT, SRC-AWS-SRA, SRC-AWS-CT, SRC-GCP-FOUNDATIONS, SRC-NIST-800-53, SRC-EU-NIS2
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that F1 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-F1 finding requires the capability as the replacement control.

Control purpose and rationale

Organization activity (Entra, CloudTrail, Cloud Audit Logs) is exported to a platform log landing zone with retention and immutability appropriate to the risk. This tactic provides the controlled remediation mechanism for the locked F1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for F1 using live control-plane inventory.
- Design the mechanism: Centralize and Protect Activity and Audit Logs; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- organization logging architecture
- central immutable destination
- retention/access policy
- end-to-end delivery and tamper tests
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are tenant, organization or account activity logs exported centrally, not left in each landing zone?
- Evidence answers YES: Is retention and immutability defined and met?
- Evidence answers YES: Can security and platform query those logs without asking application teams?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Activity Log + Entra diagnostic settings to central Log Analytics / Storage; MG-level.
- AWS: Org CloudTrail to Log Archive account; integrity validation; no trail gaps.
- GCP: Org-level Cloud Audit Logs sinks to a logging project; no sink exclusions that drop admin activity.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Log rerouting can create a visibility gap or unexpected ingestion and retention cost.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess F1, AP-F1, E2, F3, G5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-OPERATIONS-F2-01

CAPABILITY · DOMAIN F

Make Live Control-Plane Inventory the System of Record

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: F2 · Pair: AP-F2 · Supporting/reuse: A1, C1, G5
PRIMARY OWNER	Cloud Platform Operations Owner
SUPPORTING ROLES	SRE/Operations, Security Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-MANAGEMENT, SRC-AWS-SRA, SRC-GCP-HIERARCHY, SRC-CISA-CLOUD-TRA
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that F2 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-F2 finding requires the capability as the replacement control.

Control purpose and rationale

The platform can list isolation units, policy assignments and network paths from APIs this week. Spreadsheets are a cache, not the system of record. This tactic provides the controlled remediation mechanism for the locked F2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for F2 using live control-plane inventory.
- Design the mechanism: Make Live Control-Plane Inventory the System of Record; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- inventory query and export process
- scope reconciliation report
- ownership and exception register
- scheduled freshness evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Can the platform export the current hierarchy, policy assignments and identity bindings on demand?
- Evidence answers YES: Is that export used as assessment evidence rather than a slide from last year?
- Evidence answers YES: Are unknown isolation units a finding, not a surprise in the workshop?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Resource Graph, Management Group API, Policy insights, Entra PIM export.
- AWS: Organizations, Config aggregator, IAM Access Analyzer, Resource Explorer.
- GCP: Cloud Asset Inventory, Resource Manager, Policy Analyzer, SCC assets.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Inventory aggregation can expose sensitive metadata and must preserve access boundaries.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess F2, AP-F2, A1, C1, G5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-OPERATIONS-F3-01

CAPABILITY · DOMAIN F

Monitor the Landing-Zone Platform Baseline

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: F3 · Pair: AP-F3 · Supporting/reuse: D2, E2, F1
PRIMARY OWNER	Cloud Platform Operations Owner
SUPPORTING ROLES	SRE/Operations, Security Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-MANAGEMENT, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS, SRC-CISA-CLOUD-TRA
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that F3 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-F3 finding requires the capability as the replacement control.

Control purpose and rationale

Platform health (identity, network, policy, logging pipeline) has monitors. Application APM is welcome; it is not a substitute for platform observability. This tactic provides the controlled remediation mechanism for the locked F3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for F3 using live control-plane inventory.
- Design the mechanism: Monitor the Landing-Zone Platform Baseline; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- platform service-level indicators
- monitor and alert configuration
- ownership/escalation matrix
- alert exercise evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are there monitors on the logging pipeline, hybrid connectivity, policy compliance and identity health?
- Evidence answers YES: Do those alerts reach a platform on-call, not only an application team?
- Evidence answers YES: Is 'we have Azure Monitor / CloudWatch / Cloud Monitoring' evidenced for the platform plane, not only for one app?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Azure Monitor / Service Health / Policy compliance alerts on platform subscriptions.
- AWS: CloudWatch on org trail, TGW, Config; Control Tower lifecycle events.
- GCP: Cloud Monitoring on sinks, Interconnect, org policies; Essential Contacts.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Unprioritized platform telemetry can create alert fatigue and obscure high-impact failures.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess F3, AP-F3, D2, E2, F1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-OPERATIONS-F4-01

CAPABILITY · DOMAIN F

Implement and Exercise Landing-Zone Backup and Restore

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: F4 · Pair: AP-F4 · Supporting/reuse: A5, D3, H1
PRIMARY OWNER	Platform Resilience Owner
SUPPORTING ROLES	Cloud Platform, Identity, Network, Security and Continuity Management
APPROVED SOURCE IDS	SRC-MS-CAF-MANAGEMENT, SRC-NIST-800-53, SRC-ISO-27001, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that F4 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-F4 finding requires the capability as the replacement control.

Control purpose and rationale

The landing zone itself — identity config, DNS, policy, IaC state, key material — has a restore story. Application backup does not restore the foundation. This tactic provides the controlled remediation mechanism for the locked F4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for F4 using live control-plane inventory.
- Design the mechanism: Implement and Exercise Landing-Zone Backup and Restore; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- platform asset recovery scope
- backup/versioning configuration
- restore runbooks
- representative restore test evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a restore path for platform configuration (IaC state, DNS, policy, identity)?
- Evidence answers YES: Are key-vault / KMS and secret restores tested?
- Evidence answers YES: Has a platform restore been rehearsed, not only documented?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: IaC repos + state; Key Vault backup; Recovery Services for platform where relevant.
- AWS: AFT/Control Tower backup, Route 53, KMS CMKs, org trail bucket versioning.
- GCP: Terraform state backup, Cloud DNS export, KMS, org-policy export.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Untested restoration may overwrite current state or restore secrets and keys into an unsafe context.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess F4, AP-F4, A5, D3, H1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-OPERATIONS-F5-01

CAPABILITY · DOMAIN F

Standardize the Platform Update and Agent Baseline

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: F5 · Pair: AP-F5 · Supporting/reuse: E1, H1, H5
PRIMARY OWNER	Cloud Platform Operations Owner
SUPPORTING ROLES	SRE/Operations, Security Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-MANAGEMENT, SRC-MS-MCSB-V1, SRC-AWS-WA-SECURITY, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that F5 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-F5 finding requires the capability as the replacement control.

Control purpose and rationale

Guest OS, agents, and policy deployments that the platform owns have an update path. Snowflake images are exceptions with owners. This tactic provides the controlled remediation mechanism for the locked F5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for F5 using live control-plane inventory.
- Design the mechanism: Standardize the Platform Update and Agent Baseline; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- approved image/agent catalogue
- update ownership and cadence
- exception register
- coverage and patch-state export
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a platform-owned update path for OS, agents or policy guest configuration in scope?
- Evidence answers YES: Are unmanaged agents and golden-image drift visible?
- Evidence answers YES: Is 'we use Kubernetes so this does not apply' evidenced, not assumed, where relevant?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Azure Update Manager / Automanage / Arc; policy guest configuration.
- AWS: Systems Manager patch, State Manager; no unmanaged instances outside SSM.
- GCP: VM Manager / OS Config; no unmanaged GCE fleets if GCE is in scope.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Standardization can break workloads that depend on unsupported agents or image customizations.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess F5, AP-F5, E1, H1, H5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-OPERATIONS-AP-F1-01

ANTI-PATTERN · DOMAIN F

Recover Logs from Producing Accounts and Correct Retention

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-F1 · Pair: F1 · Supporting/reuse: E2, F3, G5
PRIMARY OWNER	Cloud Platform Operations Owner
SUPPORTING ROLES	SRE/Operations, Security Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-MANAGEMENT, SRC-AWS-SRA, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-F1 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Activity logs stay in the producing account, expire at default, and disappear. Forensics starts with 'we no longer have that'. This tactic provides the controlled remediation mechanism for the locked AP-F1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of logs left in the subscription and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Centralize and Protect Activity and Audit Logs.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-F1 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- organization logging architecture
- central immutable destination
- retention/access policy
- end-to-end delivery and tamper tests
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are organization activity logs not exported from the producing landing zone?
- Absence test answers NO across the in-scope estate: Is default retention the de-facto policy?
- Absence test answers NO across the in-scope estate: Would an incident older than a few weeks be unreconstructable?
- The paired capability F1 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No diagnostic settings at MG; 90-day Activity Log only.
- AWS: No org CloudTrail; per-account trails off or 7-day.
- GCP: No org sink; default 30-day audit logs.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Log rerouting can create a visibility gap or unexpected ingestion and retention cost.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-F1, F1, E2, F3, G5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-OPERATIONS-AP-F2-01

ANTI-PATTERN · DOMAIN F

Replace Stale Diagrams with Current API Inventory

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-F2 · Pair: F2 · Supporting/reuse: A1, C1, G5
PRIMARY OWNER	Cloud Platform Operations Owner
SUPPORTING ROLES	SRE/Operations, Security Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-MANAGEMENT, SRC-AWS-ORG-STRATEGY, SRC-GCP-HIERARCHY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-F2 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

The estate map is a draw.io from a previous consultant. New accounts appear in the invoice first. This tactic provides the controlled remediation mechanism for the locked AP-F2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of no current inventory and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Make Live Control-Plane Inventory the System of Record.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-F2 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- inventory query and export process
- scope reconciliation report
- ownership and exception register
- scheduled freshness evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is there no API-fresh inventory of isolation units?
- Absence test answers NO across the in-scope estate: Do invoices or workshops discover accounts the platform did not know?
- Absence test answers NO across the in-scope estate: Is policy assignment state unknown?
- The paired capability F2 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No Resource Graph practice; MG tree in a slide.
- AWS: No Config aggregator; Organizations console rarely opened.
- GCP: No Asset Inventory; project list from memory.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Inventory aggregation can expose sensitive metadata and must preserve access boundaries.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-F2, F2, A1, C1, G5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-OPERATIONS-AP-F3-01

ANTI-PATTERN · DOMAIN F

Extend Monitoring Beyond Applications

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-F3 · Pair: F3 · Supporting/reuse: D2, E2, F1
PRIMARY OWNER	Cloud Platform Operations Owner
SUPPORTING ROLES	SRE/Operations, Security Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-MANAGEMENT, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-F3 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

APM is excellent. The logging pipeline, ExpressRoute, org trail and policy engine have no owner and no alert. This tactic provides the controlled remediation mechanism for the locked AP-F3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of application monitoring only and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Monitor the Landing-Zone Platform Baseline.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-F3 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- platform service-level indicators
- monitor and alert configuration
- ownership/escalation matrix
- alert exercise evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are platform-plane services unmonitored while applications are?
- Absence test answers NO across the in-scope estate: Would a failed log export be noticed only in an audit?
- Absence test answers NO across the in-scope estate: Is there no platform on-call?
- The paired capability F3 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: App Insights everywhere; no alert on diagnostic-setting deletion.
- AWS: CW on Lambdas; org trail delivery failures unalerted.
- GCP: App SRE golden signals; sink failures silent.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Unprioritized platform telemetry can create alert fatigue and obscure high-impact failures.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-F3, F3, D2, E2, F1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-OPERATIONS-AP-F4-01

ANTI-PATTERN · DOMAIN F

Recover Unprotected Platform State

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-F4 · Pair: F4 · Supporting/reuse: A5, D3, H1
PRIMARY OWNER	Platform Resilience Owner
SUPPORTING ROLES	Cloud Platform, Identity, Network, Security and Continuity Management
APPROVED SOURCE IDS	SRC-MS-CAF-MANAGEMENT, SRC-NIST-800-53, SRC-ISO-27001
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-F4 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Application backup is mature. The landing zone IaC state, DNS and keys have one copy on one laptop. This tactic provides the controlled remediation mechanism for the locked AP-F4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of no platform restore and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Implement and Exercise Landing-Zone Backup and Restore.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-F4 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- platform asset recovery scope
- backup/versioning configuration
- restore runbooks
- representative restore test evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is platform configuration unrestoreable except by tribal knowledge?
- Absence test answers NO across the in-scope estate: Is Terraform/Bicep/Pulumi state on a laptop or an unversioned storage account?
- Absence test answers NO across the in-scope estate: Have restores never been rehearsed?
- The paired capability F4 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Local ARM templates; Key Vault purge protection off.
- AWS: Local Terraform state; org trail bucket without versioning.
- GCP: State in a personal GCS bucket; no KMS backup story.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Untested restoration may overwrite current state or restore secrets and keys into an unsafe context.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-F4, F4, A5, D3, H1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-OPERATIONS-AP-F5-01

ANTI-PATTERN · DOMAIN F

Retire Snowflake Images and Unmanaged Agents

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-F5 · Pair: F5 · Supporting/reuse: E1, H1, H5
PRIMARY OWNER	Cloud Platform Operations Owner
SUPPORTING ROLES	SRE/Operations, Security Operations and Service Owners
APPROVED SOURCE IDS	SRC-MS-MCSB-V1, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-F5 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Every team brings an agent, an image, and an exception. The platform cannot patch, observe or retire them. This tactic provides the controlled remediation mechanism for the locked AP-F5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of snowflake agents and images and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Standardize the Platform Update and Agent Baseline.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-F5 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- approved image/agent catalogue
- update ownership and cadence
- exception register
- coverage and patch-state export
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are guest agents and images unmanaged exceptions as the default?
- Absence test answers NO across the in-scope estate: Can the platform not tell what is running on compute it hosts?
- Absence test answers NO across the in-scope estate: Is drift from the golden image invisible?
- The paired capability F5 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No Azure Arc/Update Manager coverage; custom images untracked.
- AWS: SSM agent missing; unmanaged AMIs.
- GCP: OS Config off; mystery GCE images.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Standardization can break workloads that depend on unsupported agents or image customizations.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-F5, F5, E1, H1, H5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

Domain G - Governance & policy

Namespace: GOVERNANCE · 10 tactic objects · Primary ownership: Cloud Governance Owner

Workshop themes

- What does the platform actually deny, versus what it merely audits?
- How is an exemption born, lived, and killed?
- Can compliance evidence be exported, or only screenshot?

Domain control intent

Use the GOVERNANCE catalogue only after an exact Domain G finding is locked. Capability-building tactics establish the target mechanism; anti-pattern tactics contain and correct the harmful observed state. Supporting roles: Cloud Platform, Security, FinOps, Risk and Compliance.

TAC-GOVERNANCE-G1-01

CAPABILITY · DOMAIN G

Assign and Inherit Guardrails from the Root

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: G1 · Pair: AP-G1 · Supporting/reuse: C1, E1, H1
PRIMARY OWNER	Cloud Governance Owner
SUPPORTING ROLES	Cloud Platform, Security, FinOps, Risk and Compliance
APPROVED SOURCE IDS	SRC-MS-CAF-GOVERNANCE, SRC-MS-AZURE-POLICY, SRC-AWS-SCP, SRC-GCP-ORGPOLICY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that G1 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-G1 finding requires the capability as the replacement control.

Control purpose and rationale

Guardrails are assigned at hierarchy nodes and inherited. Per-subscription policy as a cottage industry is the exception, not the system. This tactic provides the controlled remediation mechanism for the locked G1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for G1 using live control-plane inventory.
- Design the mechanism: Assign and Inherit Guardrails from the Root; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- policy hierarchy and assignment map
- versioned guardrail set
- inheritance validation
- compliance and exception export
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are core guardrails assigned at management group, OU or folder — not only on individual isolation units?
- Evidence answers YES: Can the platform show effective policy on a given landing zone?
- Evidence answers YES: Are conflicting assignments visible and owned?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Azure Policy at MG with initiative sets; Policy Insights effective assignments.
- AWS: SCPs on OUs; RCP/declarative policies if used; Access Analyzer.
- GCP: Organization Policy on org/folders; hierarchy evaluation.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Root assignments can create widespread impact when scope, effects or exclusions are misunderstood.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess G1, AP-G1, C1, E1, H1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-GOVERNANCE-G2-01

CAPABILITY · DOMAIN G

Deny High-Blast-Radius Insecure Defaults

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: G2 · Pair: AP-G2 · Supporting/reuse: D4, E1, G3
PRIMARY OWNER	Cloud Governance Owner
SUPPORTING ROLES	Cloud Platform, Security, FinOps, Risk and Compliance
APPROVED SOURCE IDS	SRC-MS-AZURE-POLICY, SRC-MS-MCSB-V1, SRC-AWS-SCP, SRC-GCP-ORGPOLICY, SRC-CIS-AZURE, SRC-CIS-AWS, SRC-CIS-GCP
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that G2 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-G2 finding requires the capability as the replacement control.

Control purpose and rationale

A small, named set of high-blast-radius actions is denied (public data, disable logging, leave the org, user-access-admin). Audit-only is not a deny. This tactic provides the controlled remediation mechanism for the locked G2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for G2 using live control-plane inventory.
- Design the mechanism: Deny High-Blast-Radius Insecure Defaults; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- named deny control set
- staged impact analysis
- root/hierarchy assignments
- negative and exception-path tests
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a named deny set for high-blast-radius misconfigurations?
- Evidence answers YES: Are those denials in force on production landing zones, not only in a sandbox?
- Evidence answers YES: Is audit-only clearly labelled as detection, not prevention?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Deny/modify policies for public IP, public storage, allowed locations, required diagnostics.
- AWS: SCP deny s3:PutBucketPublic, leave-org, root user, disable CloudTrail/Config.
- GCP: constraints/compute.vmExternalIpAccess, storage.publicAccessPrevention, iam.disableServiceAccountKeyCreation.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A deny control deployed without simulation may block recovery or essential organization services.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess G2, AP-G2, D4, E1, G3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-GOVERNANCE-G3-01

CAPABILITY · DOMAIN G

Govern Exceptions with Owner, Expiry and Review

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: G3 · Pair: AP-G3 · Supporting/reuse: G1, G2, H5
PRIMARY OWNER	Cloud Governance Owner
SUPPORTING ROLES	Cloud Platform, Security, FinOps, Risk and Compliance
APPROVED SOURCE IDS	SRC-MS-AZURE-POLICY, SRC-AWS-SCP, SRC-GCP-ORGPOLICY, SRC-NIST-800-53
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that G3 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-G3 finding requires the capability as the replacement control.

Control purpose and rationale

Every exemption has a named owner, a reason, an expiry and a review. Permanent 'exclude this MG' is itself a finding. This tactic provides the controlled remediation mechanism for the locked G3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for G3 using live control-plane inventory.
- Design the mechanism: Govern Exceptions with Owner, Expiry and Review; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- exception schema and workflow
- owner/expiry register
- automated expiry/review controls
- closed and reauthorized exception evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are policy exemptions recorded with owner, reason and expiry?
- Evidence answers YES: Is there a review cadence that actually retires them?
- Evidence answers YES: Are root-level exclusions treated as landing-zone risk, not housekeeping?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Azure Policy exemption resources with expiresOn; waiver process.
- AWS: SCP OU exclusions documented; Control Tower detective/preventive skip list with tickets.
- GCP: Org-policy custom constraints / allow lists with owners; no silent restoreDefault.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Bulk expiry can create outages if legitimate dependencies were never documented.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess G3, AP-G3, G1, G2, H5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-GOVERNANCE-G4-01

CAPABILITY · DOMAIN G

Enforce Cost, Tag and Region Guardrails

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: G4 · Pair: AP-G4 · Supporting/reuse: A3, C3, H2
PRIMARY OWNER	Cloud Governance / FinOps Owner
SUPPORTING ROLES	Cloud Platform, Finance, Privacy and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-GOVERNANCE, SRC-AWS-ORG-STRATEGY, SRC-GCP-ORGPOLICY, SRC-EU-GDPR
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that G4 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-G4 finding requires the capability as the replacement control.

Control purpose and rationale

The landing zone enforces the commercial minimum: required tags, allowed regions, maybe budgets. FinOps is a consumer of this; it is not a substitute for it. This tactic provides the controlled remediation mechanism for the locked G4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for G4 using live control-plane inventory.
- Design the mechanism: Enforce Cost, Tag and Region Guardrails; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- required tag and region policy
- budget/owner integration
- enforcement or vending rules
- violation and remediation export
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are required tags or labels enforced at vending or by policy?
- Evidence answers YES: Are allowed regions constrained?
- Evidence answers YES: Are budgets or cost-anomaly signals attached to landing zones with owners?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: required-tags policy; allowed locations; Management Group budgets / Cost Management.
- AWS: Tag policies; allowed-region SCP; Budgets on accounts.
- GCP: labels + org policy resource locations; budgets on billing accounts/folders.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Region restrictions and mandatory tags can conflict with resilience, sovereignty or service availability.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess G4, AP-G4, A3, C3, H2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-GOVERNANCE-G5-01

CAPABILITY · DOMAIN G

Produce Queryable Compliance Evidence

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: G5 · Pair: AP-G5 · Supporting/reuse: F2, F1, E1
PRIMARY OWNER	Cloud Governance Owner
SUPPORTING ROLES	Cloud Platform, Security, FinOps, Risk and Compliance
APPROVED SOURCE IDS	SRC-MS-AZURE-POLICY, SRC-MS-MCSB-V1, SRC-AWS-SRA, SRC-GCP-FOUNDATIONS, SRC-EU-NIS2
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that G5 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-G5 finding requires the capability as the replacement control.

Control purpose and rationale

Compliance is a query (policy compliance, Config, SCC posture), not a screenshot of a dashboard from last quarter. This tactic provides the controlled remediation mechanism for the locked G5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for G5 using live control-plane inventory.
- Design the mechanism: Produce Queryable Compliance Evidence; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- versioned compliance query/export
- scope and timestamp metadata
- finding ownership linkage
- reproduction and integrity check
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Can the platform export current compliance against the assigned baseline?
- Evidence answers YES: Is that export used as assessment evidence?
- Evidence answers YES: Are non-compliant resources owned, not only counted?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Azure Policy compliance + Resource Graph; Defender regulatory standards if in scope.
- AWS: Config conformance, Security Hub standards, Audit Manager if in scope.
- GCP: SCC posture / Compliance reports; Policy Analyzer.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A dashboard export can appear complete while excluding assets, policies or providers from scope.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess G5, AP-G5, F2, F1, E1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-GOVERNANCE-AP-G1-01

ANTI-PATTERN · DOMAIN G

Convert Policy Documents into Enforced Control-Plane Assignments

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-G1 · Pair: G1 · Supporting/reuse: C1, E1, H1
PRIMARY OWNER	Cloud Governance Owner
SUPPORTING ROLES	Cloud Platform, Security, FinOps, Risk and Compliance
APPROVED SOURCE IDS	SRC-MS-CAF-GOVERNANCE, SRC-MS-CAF-DESIGN-PRINCIPLES, SRC-AWS-SCP, SRC-GCP-ORGPOLICY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-G1 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

There is a beautiful standard. Nothing in the control plane assigns it. Workshops recite it. The API does not. This tactic provides the controlled remediation mechanism for the locked AP-G1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of policy as documentation only and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Assign and Inherit Guardrails from the Root.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-G1 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- policy hierarchy and assignment map
- versioned guardrail set
- inheritance validation
- compliance and exception export
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is the guardrail set documented but not assigned in the control plane?
- Absence test answers NO across the in-scope estate: Do new landing zones boot without the baseline?
- Absence test answers NO across the in-scope estate: Is 'we plan to enable policy next quarter' the current state?
- The paired capability G1 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: CAF deck, no Policy assignments at MG.
- AWS: Well-Architected whitepaper, empty SCPs (FullAWSAccess only).
- GCP: Security whitepaper, org policies at default.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Root assignments can create widespread impact when scope, effects or exclusions are misunderstood.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-G1, G1, C1, E1, H1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-GOVERNANCE-AP-G2-01

ANTI-PATTERN · DOMAIN G

Replace Root Allow-All with a Minimal Preventive Baseline

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-G2 · Pair: G2 · Supporting/reuse: D4, E1, G3
PRIMARY OWNER	Cloud Governance Owner
SUPPORTING ROLES	Cloud Platform, Security, FinOps, Risk and Compliance
APPROVED SOURCE IDS	SRC-AWS-SCP, SRC-MS-AZURE-POLICY, SRC-GCP-ORGPOLICY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-G2 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

The only org-level policy is FullAWSAccess, an empty initiative, or restoreDefault. Prevention lives in goodwill. This tactic provides the controlled remediation mechanism for the locked AP-G2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of root-level allow-all and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Deny High-Blast-Radius Insecure Defaults.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-G2 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- named deny control set
- staged impact analysis
- root/hierarchy assignments
- negative and exception-path tests
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is the effective organization policy equivalent to allow-all?
- Absence test answers NO across the in-scope estate: Can any landing zone disable logging, attach public IPs, or leave the org?
- Absence test answers NO across the in-scope estate: Are denies present only in a lab?
- The paired capability G2 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No deny assignments; Audit-only everywhere.
- AWS: FullAWSAccess on Root; no additional SCPs.
- GCP: All org policies at default / inherit.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A deny control deployed without simulation may block recovery or essential organization services.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-G2, G2, D4, E1, G3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-GOVERNANCE-AP-G3-01

ANTI-PATTERN · DOMAIN G

Expire or Reauthorize Permanent Exemptions

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-G3 · Pair: G3 · Supporting/reuse: G1, G2, H5
PRIMARY OWNER	Cloud Governance Owner
SUPPORTING ROLES	Cloud Platform, Security, FinOps, Risk and Compliance
APPROVED SOURCE IDS	SRC-MS-AZURE-POLICY, SRC-AWS-SCP, SRC-GCP-ORGPOLICY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-G3 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Whole management groups, OUs or folders are excluded 'for now'. Now is three years old. The excluded node holds production. This tactic provides the controlled remediation mechanism for the locked AP-G3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of permanent exemptions and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Govern Exceptions with Owner, Expiry and Review.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-G3 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- exception schema and workflow
- owner/expiry register
- automated expiry/review controls
- closed and reauthorized exception evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are hierarchy nodes excluded from policy with no expiry?
- Absence test answers NO across the in-scope estate: Does the excluded node contain production?
- Absence test answers NO across the in-scope estate: Is the exemption undocumented or owned by a departed person?
- The paired capability G3 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: MG excluded from MCSB; expiresOn null.
- AWS: OU without SCPs; Control Tower ungoverned OU with prod accounts.
- GCP: Folder with restored defaults; production projects inside.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Bulk expiry can create outages if legitimate dependencies were never documented.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-G3, G3, G1, G2, H5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-GOVERNANCE-AP-G4-01

ANTI-PATTERN · DOMAIN G

Establish Minimum Commercial and Geographic Controls

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-G4 · Pair: G4 · Supporting/reuse: A3, C3, H2
PRIMARY OWNER	Cloud Governance / FinOps Owner
SUPPORTING ROLES	Cloud Platform, Finance, Privacy and Service Owners
APPROVED SOURCE IDS	SRC-MS-CAF-GOVERNANCE, SRC-AWS-SCP, SRC-GCP-ORGPOLICY
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-G4 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Any region, no tags, no budgets. The landing zone will happily host a GPU farm in an unapproved geography. This tactic provides the controlled remediation mechanism for the locked AP-G4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of no cost or region guardrail and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Enforce Cost, Tag and Region Guardrails.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-G4 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- required tag and region policy
- budget/owner integration
- enforcement or vending rules
- violation and remediation export
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Can resources be created in any region without policy friction?
- Absence test answers NO across the in-scope estate: Are tags optional?
- Absence test answers NO across the in-scope estate: Do landing zones have no budget owner?
- The paired capability G4 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No allowed-locations; no required-tags; no MG budgets.
- AWS: No region SCP; no tag policies; no Budgets.
- GCP: No resourceLocations constraint; no labels; no budgets.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Region restrictions and mandatory tags can conflict with resilience, sovereignty or service availability.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-G4, G4, A3, C3, H2. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-GOVERNANCE-AP-G5-01

ANTI-PATTERN · DOMAIN G

Replace Screenshot Compliance with Reproducible Exports

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-G5 · Pair: G5 · Supporting/reuse: F2, F1, E1
PRIMARY OWNER	Cloud Governance Owner
SUPPORTING ROLES	Cloud Platform, Security, FinOps, Risk and Compliance
APPROVED SOURCE IDS	SRC-MS-AZURE-POLICY, SRC-CISA-CLOUD-TRA, SRC-AWS-SRA
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-G5 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Evidence of control is a PDF of a dashboard, a workshop assertion, or a vendor questionnaire. The control plane was not queried. This tactic provides the controlled remediation mechanism for the locked AP-G5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of screenshot compliance and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Produce Queryable Compliance Evidence.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-G5 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- versioned compliance query/export
- scope and timestamp metadata
- finding ownership linkage
- reproduction and integrity check
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is compliance evidenced only by slides, questionnaires or screenshots?
- Absence test answers NO across the in-scope estate: Was the control plane not queried for this assessment?
- Absence test answers NO across the in-scope estate: Do findings say 'we believe we are compliant' without an export?
- The paired capability G5 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No Policy Insights export; CAF checklist ticked in a workshop.
- AWS: No Config aggregator export; WAFR notes as evidence.
- GCP: No SCC posture export; workshop scores as evidence.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A dashboard export can appear complete while excluding assets, policies or providers from scope.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-G5, G5, F2, F1, E1. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

Domain H - Platform automation & DevOps

Namespace: AUTOMATION · 10 tactic objects · Primary ownership: Platform Engineering / DevOps Owner

Workshop themes

- Is the landing zone born from code, or from a portal?
- How does drift get detected, and who is allowed to hotfix the foundation?
- Can an application team request a landing zone without a six-week ticket?

Domain control intent

Use the AUTOMATION catalogue only after an exact Domain H finding is locked. Capability-building tactics establish the target mechanism; anti-pattern tactics contain and correct the harmful observed state.

Supporting roles: Cloud Platform, Security, Change Management and Product Teams.

TAC-AUTOMATION-H1-01

CAPABILITY · DOMAIN H

Codify and Version the Landing-Zone Platform

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: H1 · Pair: AP-H1 · Supporting/reuse: H3, H5, F4
PRIMARY OWNER	Platform Engineering / DevOps Owner
SUPPORTING ROLES	Cloud Platform, Security, Change Management and Product Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-AWS-LZA, SRC-AWS-AFT, SRC-GCP-FOUNDATIONS, SRC-GCP-TFT-FOUNDATION, SRC-AZURE-ALZ-GITHUB
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that H1 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-H1 finding requires the capability as the replacement control.

Control purpose and rationale

Hierarchy, policy, identity grants, hub network and logging sinks are in versioned IaC with review. The portal is for break-glass, not for the weekly change. This tactic provides the controlled remediation mechanism for the locked H1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for H1 using live control-plane inventory.
- Design the mechanism: Codify and Version the Landing-Zone Platform; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- version-controlled platform code
- state/import and module design
- review/promotion workflow
- representative plan and apply evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Are the platform landing zones defined in versioned IaC (Terraform, Bicep, CDK, Pulumi, Config Connector)?
- Evidence answers YES: Do reviews and promotions follow a pipeline, not a shared admin login?
- Evidence answers YES: Is portal change of platform resources treated as drift?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Bicep/Terraform ALZ; policy-as-code; GitHub/ADO with PR.
- AWS: Control Tower + AFT / Landing Zone Accelerator / custom Terraform; no console-first org changes.
- GCP: Terraform foundation (project factory, org policy); Config Connector if used.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Importing a live estate into code can trigger destructive changes if state and ownership are wrong.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess H1, AP-H1, H3, H5, F4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-AUTOMATION-H2-01

CAPABILITY · DOMAIN H

Implement an End-to-End Landing-Zone Vending Pipeline

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: H2 · Pair: AP-H2 · Supporting/reuse: C4, H4, C3
PRIMARY OWNER	Platform Engineering / DevOps Owner
SUPPORTING ROLES	Cloud Platform, Security, Change Management and Product Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-AWS-AFT, SRC-AWS-CT, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that H2 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-H2 finding requires the capability as the replacement control.

Control purpose and rationale

A request becomes a landing zone with identity, network, policy and logging already on. Human time is approval, not clicking 40 blades. This tactic provides the controlled remediation mechanism for the locked H2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for H2 using live control-plane inventory.
- Design the mechanism: Implement an End-to-End Landing-Zone Vending Pipeline; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- service request schema
- pipeline and approval workflow
- baseline attachment automation
- lead-time and conformance evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a pipeline or catalog item that vends a subscription, account or project into the right node?
- Evidence answers YES: Does the vended unit boot with the baseline attached?
- Evidence answers YES: Is the request-to-ready time measured?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Subscription vending workflow / ALZ accelerator / service catalog.
- AWS: Account Factory / AFT / Service Catalog.
- GCP: Project factory pipeline + IAM + Shared VPC attachment.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Vending automation can rapidly reproduce insecure defaults or incorrect ownership.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess H2, AP-H2, C4, H4, C3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-AUTOMATION-H3-01

CAPABILITY · DOMAIN H

Detect, Triage and Correct Platform Drift

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: H3 · Pair: AP-H3 · Supporting/reuse: H1, H5, G5
PRIMARY OWNER	Platform Engineering / DevOps Owner
SUPPORTING ROLES	Cloud Platform, Security, Change Management and Product Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-MS-AZURE-POLICY, SRC-AWS-CT, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that H3 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-H3 finding requires the capability as the replacement control.

Control purpose and rationale

The platform notices when reality leaves the code. Drift is a ticket with an owner, not a shrug. This tactic provides the controlled remediation mechanism for the locked H3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for H3 using live control-plane inventory.
- Design the mechanism: Detect, Triage and Correct Platform Drift; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- drift detection configuration
- triage/ownership workflow
- reconciliation decisions
- clean-plan and closure evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a drift signal on platform IaC or on policy/config?
- Evidence answers YES: Does drift create a reviewable event rather than a silent overwrite?
- Evidence answers YES: Are recurring ClickOps offenders visible?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: What-if / drift on Terraform; Azure Policy compliance; Activity Log on MG policy deletes.
- AWS: CloudFormation drift / Terraform drift; Config; Control Tower drift.
- GCP: Terraform plan in CI against org; SCC/CAI diffs; org-policy change logs.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Automated drift correction can overwrite legitimate emergency changes or destroy unmanaged resources.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess H3, AP-H3, H1, H5, G5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-AUTOMATION-H4-01

CAPABILITY · DOMAIN H

Provide Guardrailed Platform Self-Service

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: H4 · Pair: AP-H4 · Supporting/reuse: H2, C4, G4
PRIMARY OWNER	Platform Engineering / DevOps Owner
SUPPORTING ROLES	Cloud Platform, Security, Change Management and Product Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-MS-CAF-DESIGN-PRINCIPLES, SRC-AWS-AFT, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that H4 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-H4 finding requires the capability as the replacement control.

Control purpose and rationale

Application teams can get a landing zone or a spoke without a platform engineer performing the ritual. Guardrails do the saying-no. This tactic provides the controlled remediation mechanism for the locked H4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for H4 using live control-plane inventory.
- Design the mechanism: Provide Guardrailed Platform Self-Service; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- self-service product catalogue
- policy and approval boundaries
- standard request workflows
- consumer and control-conformance evidence
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Can an application team request a compliant landing zone without a platform engineer clicking it into existence?
- Evidence answers YES: Are denied requests explained by policy, not by personality?
- Evidence answers YES: Is self-service actually used, or is it a demo?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Service catalog / ARM template spec / vending app in use.
- AWS: Service Catalog / AFT requests from app teams.
- GCP: Project factory self-service with org-policy guardrails.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Self-service without observability and quotas can increase sprawl and support burden.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess H4, AP-H4, H2, C4, G4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-AUTOMATION-H5-01

CAPABILITY · DOMAIN H

Govern Platform Change and Emergency Hotfixes

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: H5 · Pair: AP-H5 · Supporting/reuse: H1, H3, F4
PRIMARY OWNER	Platform Change Owner
SUPPORTING ROLES	Platform Engineering, Operations, Security and Service Management
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-ISO-27001, SRC-NIST-800-53, SRC-AWS-CT-DESIGN
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate when a locked finding shows that H5 is below the agreed target state, one or more sub-criteria are not satisfied, or the paired AP-H5 finding requires the capability as the replacement control.

Control purpose and rationale

Changes to identity, hub, policy and logging have a path, a reviewer, and a way to stop a bad change. Hotfixes are logged as such. This tactic provides the controlled remediation mechanism for the locked H5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Confirm in-scope roots, providers, owners and target state for H5 using live control-plane inventory.
- Design the mechanism: Govern Platform Change and Emergency Hotfixes; record dependencies, decision rights and exception boundaries.
- Implement through organization-level configuration, policy, identity, network or pipeline controls appropriate to the selected provider pack.
- Migrate or reconcile existing resources and exceptions without silently redefining assessment scope.
- Run the three criterion tests, retain attributable exports/configuration and submit the new evidence for independent reassessment.

Required outputs

- platform change policy
- review and promotion evidence
- emergency-change log
- code/state reconciliation and rollback test
- implementation and reassessment evidence packet

Acceptance criteria

- Evidence answers YES: Is there a defined change path for the platform landing zones?
- Evidence answers YES: Are emergency hotfixes recorded and followed by code catch-up?
- Evidence answers YES: Can a bad policy assignment be rolled back from code, not from memory?
- Evidence is current, attributable, provider-appropriate and reproducible from the control plane.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: PR + pipeline on ALZ; break-glass portal with Activity Log and catch-up PR.
- AWS: AFT/LZA pipeline; SCP change review; break-glass with CloudTrail.
- GCP: Foundation pipeline; org-policy change review; break-glass with audit logs.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A rigid change process can delay urgent recovery; an unbounded emergency path becomes routine bypass.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess H5, AP-H5, H1, H3, F4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-AUTOMATION-AP-H1-01

ANTI-PATTERN · DOMAIN H

Bring the ClickOps Platform Under Code Control

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-H1 · Pair: H1 · Supporting/reuse: H3, H5, F4
PRIMARY OWNER	Platform Engineering / DevOps Owner
SUPPORTING ROLES	Cloud Platform, Security, Change Management and Product Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-AWS-CT-DESIGN, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-H1 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

The landing zone exists in the portal. Code, if any, is an export from last year. The next change will be another click. This tactic provides the controlled remediation mechanism for the locked AP-H1 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of clickops platform and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Codify and Version the Landing-Zone Platform.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-H1 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- version-controlled platform code
- state/import and module design
- review/promotion workflow
- representative plan and apply evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is the platform primarily configured in the console?
- Absence test answers NO across the in-scope estate: Is IaC absent, stale, or generated after the fact?
- Absence test answers NO across the in-scope estate: Would a rebuild from code fail?
- The paired capability H1 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Portal-built MG tree and Policy; ARM exports as 'IaC'.
- AWS: Console Organizations + IAM; no AFT/LZA.
- GCP: Console folders and org policies; Terraform unused.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Importing a live estate into code can trigger destructive changes if state and ownership are wrong.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-H1, H1, H3, H5, F4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-AUTOMATION-AP-H2-01

ANTI-PATTERN · DOMAIN H

Replace Email Vending with a Controlled Product Workflow

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-H2 · Pair: H2 · Supporting/reuse: C4, H4, C3
PRIMARY OWNER	Platform Engineering / DevOps Owner
SUPPORTING ROLES	Cloud Platform, Security, Change Management and Product Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-AWS-AFT, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-H2 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

A landing zone is an email to a named person who has Owner at root. Cycle time is weeks. Quality is mood. This tactic provides the controlled remediation mechanism for the locked AP-H2 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of email-request vending and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Implement an End-to-End Landing-Zone Vending Pipeline.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-H2 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- service request schema
- pipeline and approval workflow
- baseline attachment automation
- lead-time and conformance evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Is the create path an email, chat or ticket that ends in a human clicking the portal?
- Absence test answers NO across the in-scope estate: Is cycle time unmeasured or measured in weeks?
- Absence test answers NO across the in-scope estate: Do vended units differ depending on who was on shift?
- The paired capability H2 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Email to platform; portal subscription create.
- AWS: Ticket to cloud team; Organizations 'Add account'.
- GCP: Slack to GCP admin; console project.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Vending automation can rapidly reproduce insecure defaults or incorrect ownership.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-H2, H2, C4, H4, C3. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-AUTOMATION-AP-H3-01

ANTI-PATTERN · DOMAIN H

Reconcile Accepted Drift and Restore Code Authority

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-H3 · Pair: H3 · Supporting/reuse: H1, H5, G5
PRIMARY OWNER	Platform Engineering / DevOps Owner
SUPPORTING ROLES	Cloud Platform, Security, Change Management and Product Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-AWS-LZA, SRC-GCP-TFT-FOUNDATION
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-H3 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Code and cloud parted ways. Apply would be destructive, so nobody applies. The repository is literature. This tactic provides the controlled remediation mechanism for the locked AP-H3 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of drift accepted and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Detect, Triage and Correct Platform Drift.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-H3 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- drift detection configuration
- triage/ownership workflow
- reconciliation decisions
- clean-plan and closure evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Would an IaC apply be unsafe because reality has moved?
- Absence test answers NO across the in-scope estate: Is there no drift detection, or is drift ignored?
- Absence test answers NO across the in-scope estate: Is the repository no longer the system of record?
- The paired capability H3 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Terraform state years old; Policy changed in portal.
- AWS: AFT unused after initial accounts; SCPs edited live.
- GCP: Foundation repo frozen; org policies edited in console.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Automated drift correction can overwrite legitimate emergency changes or destroy unmanaged resources.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-H3, H3, H1, H5, G5. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-AUTOMATION-AP-H4-01

ANTI-PATTERN · DOMAIN H

Remove Ticket-Only Platform Bottlenecks

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-H4 · Pair: H4 · Supporting/reuse: H2, C4, G4
PRIMARY OWNER	Platform Engineering / DevOps Owner
SUPPORTING ROLES	Cloud Platform, Security, Change Management and Product Teams
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-AWS-AFT, SRC-GCP-FOUNDATIONS
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-H4 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Every spoke, DNS record and exception is a platform-engineer hour. The landing zone does not scale because the platform team is the bottleneck. This tactic provides the controlled remediation mechanism for the locked AP-H4 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of ticket-only, no self-service and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Provide Guardrailed Platform Self-Service.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-H4 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- self-service product catalogue
- policy and approval boundaries
- standard request workflows
- consumer and control-conformance evidence
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Must every landing-zone request go through a platform engineer performing the work?
- Absence test answers NO across the in-scope estate: Is there a catalog item that nobody uses?
- Absence test answers NO across the in-scope estate: Is onboarding time dominated by platform wait?
- The paired capability H4 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: No vending app; ALZ used once.
- AWS: No Account Factory access for app teams.
- GCP: No project factory; admin creates every project.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	Self-service without observability and quotas can increase sprawl and support burden.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-H4, H4, H2, C4, G4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

TAC-AUTOMATION-AP-H5-01

ANTI-PATTERN · DOMAIN H

Reconcile Undocumented Hotfixes into the Controlled Baseline

VERSION / STATUS	1.0.0 · APPROVED - ACTIVE
MAPPING	Primary: AP-H5 · Pair: H5 · Supporting/reuse: H1, H3, F4
PRIMARY OWNER	Platform Change Owner
SUPPORTING ROLES	Platform Engineering, Operations, Security and Service Management
APPROVED SOURCE IDS	SRC-MS-CAF-AUTOMATION, SRC-NIST-800-53, SRC-ISO-27001
SOURCE GROUNDING	Approved source IDs and exact criterion mappings establish the operative basis. Locator enrichment may be added through controlled updates as KB objects are finalized; current use is authorized.

Activation trigger

Activate only when finding AP-H5 is locked PRESENT or UNRESOLVED from verified in-scope evidence. Contain immediate exposure before improvement work. No locked finding means no mandatory activation.

Control purpose and rationale

Production was saved at 2 a.m. in the portal. The code was not updated. The next apply will undo the save — or nobody will ever apply again. This tactic provides the controlled remediation mechanism for the locked AP-H5 finding without changing the diagnostic rule or treating playbook content as customer evidence.

Implementation activities

- Contain further expansion of undocumented hotfixes and preserve evidence of the observed state.
- Query the full in-scope control plane; enumerate every instance, owner, dependency and time-critical exception.
- Remove, migrate or reconfigure affected objects and implement the replacement mechanism: Govern Platform Change and Emergency Hotfixes.
- Record any residual exception with owner, rationale, expiry and compensating control; do not convert an unresolved condition into an undocumented exclusion.
- Execute explicit absence tests for AP-H5 and submit the results with paired capability evidence for reassessment.

Required outputs

- containment and affected-object inventory
- platform change policy
- review and promotion evidence
- emergency-change log
- code/state reconciliation and rollback test
- tested-absence and residual-exception record

Acceptance criteria

- Absence test answers NO across the in-scope estate: Are production platform hotfixes done in the portal without a follow-up change in code?
- Absence test answers NO across the in-scope estate: Is there no break-glass record?
- Absence test answers NO across the in-scope estate: Would the next pipeline run surprise production?
- The paired capability H5 and any required supporting capability mappings have new implementation evidence; any residual exception is explicit, owned and time-bound.

Verification

- Re-run the relevant provider-pack queries against the same locked Step 0 scope.
- Azure: Policy exception in portal; no PR.
- AWS: Live SCP edit during incident; AFT unaware.
- GCP: Org policy restoreDefault during outage; repo stale.
- Compare the post-change export with the locked finding and retain timestamps, object identifiers and test results.

IMPLEMENTATION RISK	A rigid change process can delay urgent recovery; an unbounded emergency path becomes routine bypass.
RISK CONTROL	Sequence containment, dependency discovery, staged implementation and rollback; require named human approval for material production change.
DO-NOT-USE BOUNDARY	Do not activate without an exact locked finding and an in-scope provider pack. Do not use to infer legal applicability, prove the customer's current state, overwrite a stronger existing control, accept residual risk or authorize a production transition.
REASSESSMENT / CLOSURE	Reassess AP-H5, H5, H1, H3, F4. Completion creates evidence only; it never changes a finding or score, clears a gate, establishes legal compliance, accepts residual risk or authorizes lifecycle progression.

Approved source identity appendix

The following publisher identities are the approved source baseline used for criterion-to-tactic authoring. Registration and coverage do not prove customer implementation, legal applicability or control satisfaction. Exact-locator enrichment is maintained through controlled KB and playbook updates and does not limit the approved status of this release.

SRC-MS-CAF-LZ	What is an Azure landing zone? — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain A
SRC-MS-CAF-DESIGN-AREAS	Azure landing zone design areas — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain A
SRC-MS-CAF-DESIGN-PRINCIPLES	Azure landing zone design principles — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain A
SRC-MS-CAF-IDENTITY	Identity and access management design area — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-MS-CAF-RESOURCE-ORG	Resource organization design area — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain C
SRC-MS-CAF-NETWORK	Network topology and connectivity design area — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain D
SRC-MS-CAF-SECURITY	Security design area — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain E
SRC-MS-CAF-MANAGEMENT	Management design area — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain F
SRC-MS-CAF-GOVERNANCE	Governance design area — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain G
SRC-MS-CAF-AUTOMATION	Platform automation and DevOps design area — Cloud Adoption Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain H
SRC-MS-MCSB-V1	Microsoft cloud security benchmark (v1)	TIER 2 AUTHORITATIVE · PROVIDER_SECURITY_BENCHMARK · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-MS-WAF	Azure Well-Architected Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain D
SRC-MS-ENTRA-PIM	Microsoft Entra Privileged Identity Management	TIER 2 AUTHORITATIVE · PROVIDE R_PRODUCT_DOCUMENTATION · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-MS-AZURE-POLICY	Azure Policy overview	TIER 2 AUTHORITATIVE · PROVIDE R_PRODUCT_DOCUMENTATION · PUBLISHED · VERIFIED · 2026-09-15 · Domain G
SRC-AWS-CT	What is AWS Control Tower?	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain A

SRC-AWS-CT-DESIGN	Designing an AWS Control Tower landing zone — AWS Prescriptive Guidance	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain A
SRC-AWS-SRA	AWS Security Reference Architecture	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-AWS-ORG-STRATEGY	Organizing Your AWS Environment Using Multiple Accounts	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain A
SRC-AWS-SCP	Service control policies (SCPs) — AWS Organizations	TIER 2 AUTHORITATIVE · PROVIDE R_PRODUCT_DOCUMENTATION · PUBLISHED · VERIFIED · 2026-09-15 · Domain G
SRC-AWS-WA-SECURITY	AWS Well-Architected Framework — Security Pillar	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-AWS-IDENTITY-CENTER	AWS IAM Identity Center	TIER 2 AUTHORITATIVE · PROVIDE R_PRODUCT_DOCUMENTATION · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-AWS-AFT	Account Factory for Terraform (AFT)	TIER 2 AUTHORITATIVE · PROVIDE R_PRODUCT_DOCUMENTATION · PUBLISHED · VERIFIED · 2026-09-15 · Domain C
SRC-AWS-LZA	Landing Zone Accelerator on AWS	TIER 3 SUPPORTING · IMPLEMENTATION_ACCELERATOR · PUBLISHED · VERIFIED · 2026-09-15 · Domain H
SRC-GCP-LZ	Landing zone design in Google Cloud	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain A
SRC-GCP-FOUNDATIONS	Enterprise foundations blueprint (formerly security foundations)	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-GCP-HIERARCHY	Google Cloud resource hierarchy	TIER 2 AUTHORITATIVE · PROVIDE R_PRODUCT_DOCUMENTATION · PUBLISHED · VERIFIED · 2026-09-15 · Domain A
SRC-GCP-ORGPOLICY	Organization Policy Service overview	TIER 2 AUTHORITATIVE · PROVIDE R_PRODUCT_DOCUMENTATION · PUBLISHED · VERIFIED · 2026-09-15 · Domain G
SRC-GCP-SHARED-VPC	Shared VPC overview	TIER 2 AUTHORITATIVE · PROVIDE R_PRODUCT_DOCUMENTATION · PUBLISHED · VERIFIED · 2026-09-15 · Domain D
SRC-GCP-WAF	Google Cloud Well-Architected Framework	TIER 2 AUTHORITATIVE · PROVIDE R_REFERENCE_ARCHITECTURE · PUBLISHED · VERIFIED · 2026-09-15 · Domain D
SRC-NIST-800-53	NIST SP 800-53 Rev. 5 — Security and Privacy Controls	TIER 2 AUTHORITATIVE · GOVERNMENT_VOLUNTARY_GUIDANCE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-NIST-800-207	NIST SP 800-207 — Zero Trust Architecture	TIER 2 AUTHORITATIVE · GOVERNMENT_VOLUNTARY_GUIDANCE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-CISA-CLOUD-TRA	CISA Cloud Security Technical Reference Architecture v2	TIER 2 AUTHORITATIVE · MULTI_AGENCY_GOVERNMENT_GUIDANCE · PUBLISHED · VERIFIED · 2026-09-15 · Domain D

SRC-NCSC-CLOUD-PRINCIPLES	NCSC Cloud Security Principles (14 principles)	TIER 2 AUTHORITATIVE · GOVERNMENT · VOLUNTARY_GUIDANCE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-ISO-27001	ISO/IEC 27001:2022 — Information security management systems — Requirements	TIER 2 AUTHORITATIVE · PUBLISHED_STANDARD · PUBLISHED · VERIFIED · 2026-09-15 · Domain E
SRC-ISO-27017	ISO/IEC 27017:2015 — Code of practice for information security controls for cloud services	TIER 2 AUTHORITATIVE · PUBLISHED_STANDARD · PUBLISHED · VERIFIED · 2026-09-15 · Domain D
SRC-EU-NIS2	Directive (EU) 2022/2555 — NIS 2 Directive	TIER 1 NORMATIVE · LEGISLATION · IN_FORCE · VERIFIED · 2026-09-15 · Domain E
SRC-EU-GDPR	Regulation (EU) 2016/679 — General Data Protection Regulation	TIER 1 NORMATIVE · LEGISLATION · IN_FORCE · VERIFIED · 2026-09-15 · Domain D
SRC-CIS-AZURE	CIS Microsoft Azure Foundations Benchmark	TIER 3 SUPPORTING · COMMUNITY_TECHNICAL_GUIDANCE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-CIS-AWS	CIS Amazon Web Services Foundations Benchmark	TIER 3 SUPPORTING · COMMUNITY_TECHNICAL_GUIDANCE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-CIS-GCP	CIS Google Cloud Computing Platform Benchmark	TIER 3 SUPPORTING · COMMUNITY_TECHNICAL_GUIDANCE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-CSA-CCM	Cloud Security Alliance Cloud Controls Matrix (CCM)	TIER 3 SUPPORTING · COMMUNITY_TECHNICAL_GUIDANCE · PUBLISHED · VERIFIED · 2026-09-15 · Domain B
SRC-AZURE-ALZ-GITHUB	Azure Landing Zones — official implementation (Enterprise-Scale / ALZ)	TIER 3 SUPPORTING · IMPLEMENTATION_ACCELERATOR · PUBLISHED · VERIFIED · 2026-09-15 · Domain H
SRC-GCP-TFT-FOUNDATION	terraform-example-foundation — Google Cloud enterprise foundations	TIER 3 SUPPORTING · IMPLEMENTATION_ACCELERATOR · PUBLISHED · VERIFIED · 2026-09-15 · Domain H

Approved release and controlled refinement

Approved release

Version 1.0.0 is the approved and active Tactical Playbook release. It contains the complete tactic identity space, exact primary mappings, approved reuse mappings, operational activities, outputs, acceptance criteria, verification methods, risk controls and reassessment targets. It is authorized for use within the evidence-gated Landing Zone Assessment process.

Controlled maintenance as KB objects evolve

- Enrich tactic source grounding with more precise locators and supported-claim detail as corresponding KB objects are finalized.
- Refine Azure, AWS and GCP implementation language when additional provider-specific precision becomes available.
- Revalidate triggers and do-not-use conditions whenever false-positive guards or prohibited-inference rules change.
- Maintain acceptance criteria so completed work always produces the evidence class required for independent reassessment.
- Consolidate or split tactic IDs only under the formal reuse rule and update every dependency and mapping reciprocally.
- Repeat global coverage, source, mapping, ID, closure-invariant and rendering QA for every subsequent release.

Release controls satisfied by v1.0.0

MAPPING CONTROL	Every tactic has an exact approved primary mapping to a criterion or anti-pattern finding definition.
SOURCE CONTROL	Every source reference resolves to the approved Global Source Register baseline.
MECHANISM CONTROL	Objectives, activities, outputs and acceptance criteria directly address mapped deficiencies.
EVIDENCE CONTROL	Completion produces attributable evidence suitable for independent reassessment.
AUTHORITY CONTROL	No tactic text closes findings, asserts compliance, accepts risk or authorizes progression.
PROVIDER CONTROL	Provider variants preserve one shared intent and do not silently change scoring semantics.
RELEASE CONTROL	All IDs, versions, mappings and dependencies passed referential-integrity validation and human approval.

End of approved controlled catalogue · Landing Zone Assessment Tactical Playbook v1.0.0